

I) Introduction

Company named DigiTech just be attacked by an anonymous hacker. During the investigation, we found unusually activity from Mr. S account. The following report describe attack techniques in each phase and proposing solution as the defensive side to prevent similar threat in the future.

II) Phase 1: Reconnaissance

1. What happened?

The attacker utilised the OSINT framework to gather information of the company from free sources. From the company website, company emails Mr.s@definatelarealcompany.com and notascammer@definatelarealcompany.com were found. The email domains were scanned using public tools and were found to not have anti-spoofing mechanisms.

3 issue found

We found 1 issue at definatelarealcompany.com
[Check another domain](#)

Anti-spoofing

- DMARC
- SPF
- DKIM (not checked)

Email privacy

- TLS
- MTA-STS

mx:definatelarealcompany.com

Find Problems

Solve Email Delivery Problems

	Test	Result
✗	DMARC Record Published	No DMARC Record found
!	DMARC Policy Not Enabled	DMARC Quarantine/Reject policy not enabled
✓	DNS Record Published	DNS Record found

Figure 2.1.0.1&2.1.0.2 Mail scan result from <https://mxtoolbox.com> and <https://checkcybersecurity.service.ncsc.gov.uk/email-security-check>.

The attacker then attempted to forge a phishing mail to **Mr. S** pretending to be **notascammer** using Gophish ([appendix 1](#)).



Figure 2.1.0.3 Phishing email in Mr. S's outlook.

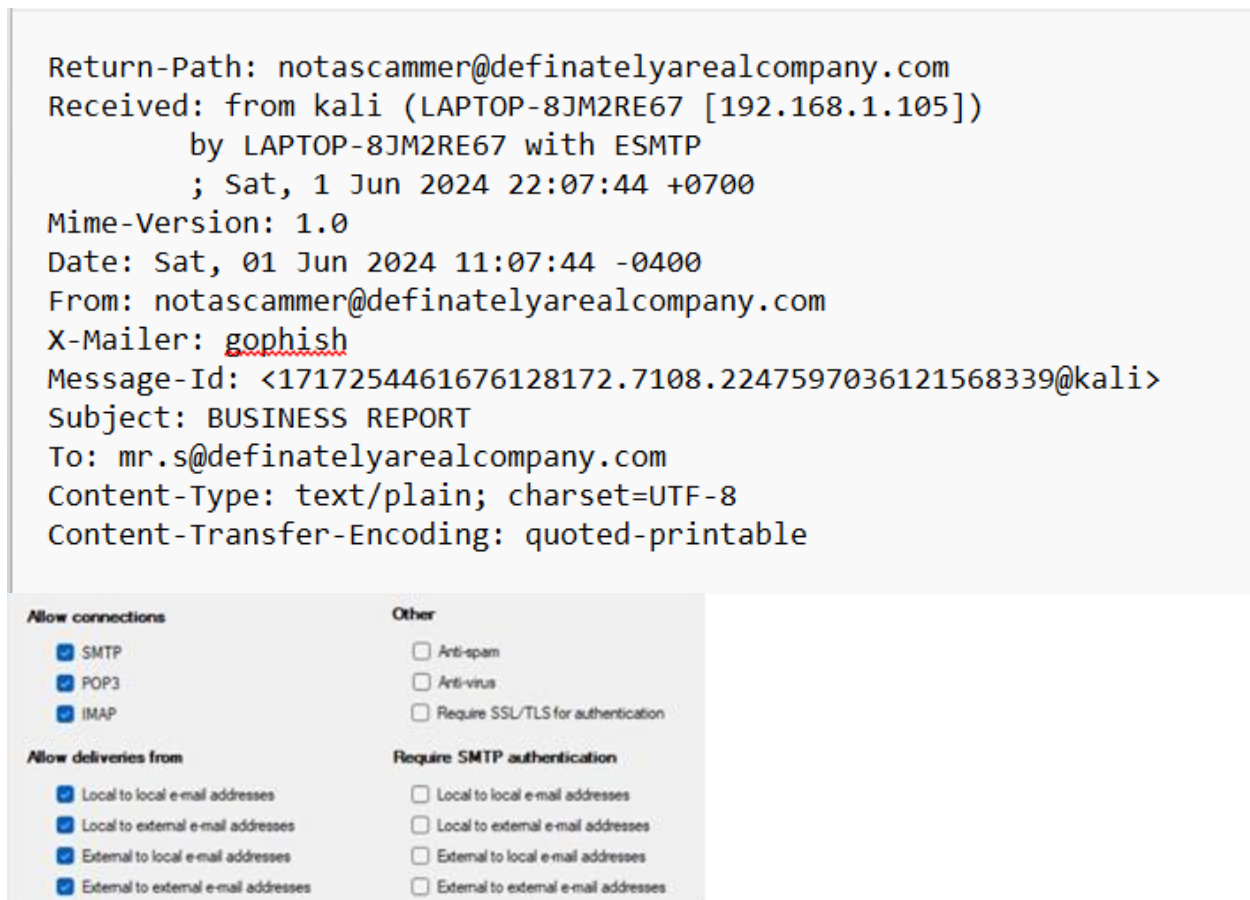


Figure 2.1.0.4&2.1.0.5 phishing mail header and company hmailserver unsecure configuration.

Upon inspecting the mail headers, the group noticed that the mail server was unsecured and did not require authentication on email headers, allowing unauthenticated and malicious emails as such being delivered.

2. Email secure protocols SPF, DKIM, DMARC

This part will cover process of securing company email domains for both self-hosted email servers and third-party email services, in this case hmailserver and google workplace.

2.1 Sender Policy Framework (SPF)

SPF prevents spoofing by specifying the mail servers allowed to send email using the company domain. SPF publishes a list authorized IP addresses in a DNS TXT record, the server validates the source IP address of email address using the domain based on the list. If email is not sent from an authorized source, it will be marked as spam or will be rejected.

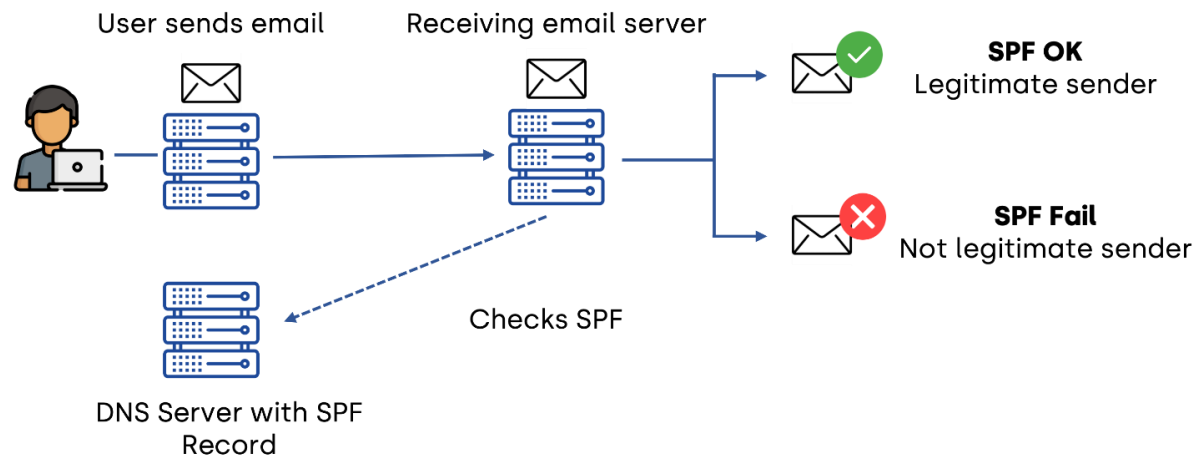


Figure 2.2.1.1 SPF graph (Mantra, 2024).

Adding SPF to domain requires creating a DNS TXT record on your domain. Since the mail server is hosted at 192.168.1.7, the following SPF record is configured so only this server can send mail from the company domain (definitelyarealcompany.com).

```
definitelyarealcompany.com. IN TXT "v=spf1 ip4:192.168.1.7 -all"
```

Figure 2.2.1.2 Mail server SPF configuration.

Similarly, google workplace emails uses google SPF record.

```
definitelyarealcompany.com|
```

TXT
TTL: 2 minutes 44 seconds VALUE: "v=spf1 include:_spf.google.com -all"
TTL: 2 minutes 44 seconds VALUE: "google-site-verification=ppZUwhH7JnurEeNRbN7-9DgWFAj1SVTwVTb8TbBo1gg"

Figure 2.2.1.3 Google workplace SPF configuration.

2.2 DomainKeys Identified Mail (DKIM)

DKIM ensures email integrity and authenticity by using a private key as a digital signature. When there is an email, the server fetches the public key to verify the signature. Emails failed to verify their signature will be quarantined or rejected.

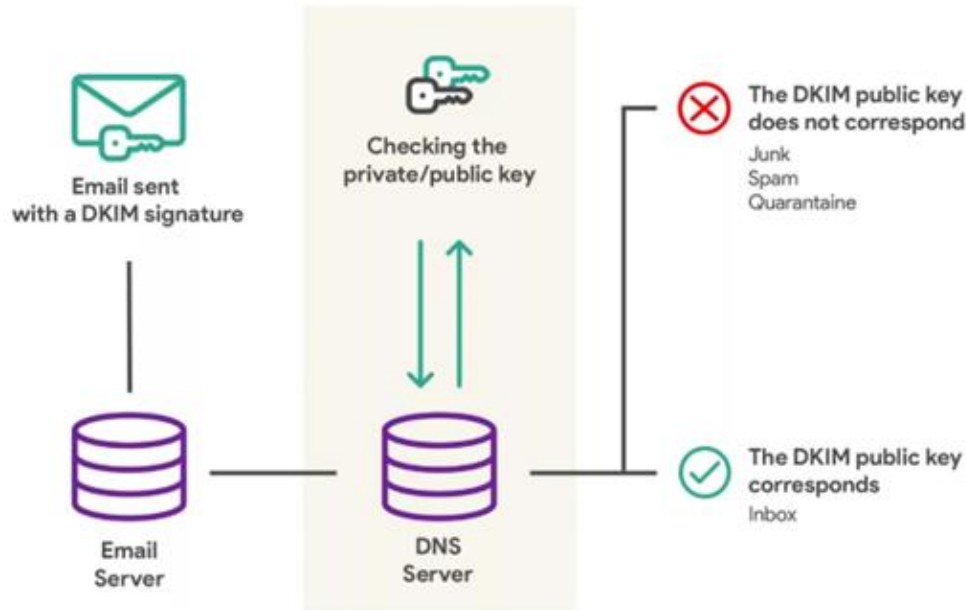
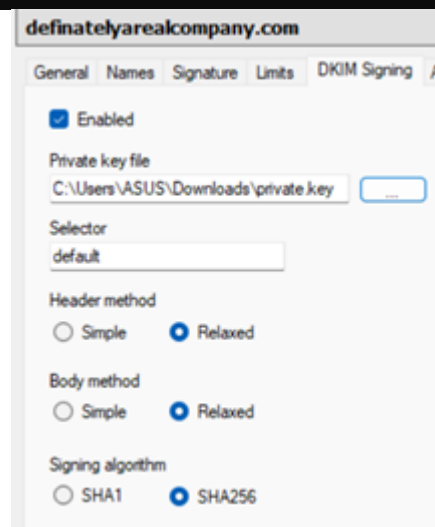


Figure 2.2.2.1 DKIM graph (Nicolas, 2024).

```
OpenSSL> genrsa -out private.key 2048
Generating RSA private key, 2048 bit long modulus (2 primes)
.....+++++
.....+++++
e is 65537 (0x010001)
OpenSSL> rsa -in private.key -out public.key -pubout -outform PEM
writing RSA key
```



```
default._domainkey.definatelyarealcompany.com. IN TXT
"v=DKIM1; k=rsa;
p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAzV2V0F5EZ
zG2K6gzZz6sd5D6lB3Q0RIsZI8Z9j..."
```

Figure 2.2.2.2&2.2.2.3&2.2.2.3 RSA key generation and mail server DKIM configuration.

A DKIM record usually contains the version of DKIM, encryption algorithm and public key. Adding DKIM to domain requires a pair of public and private key and creating a DNS TXT record. For local server, a pair of keys can be generated using OpenSSL. The server will hold the private key while the DNS TXT record uses the public key.

On google workplace, keys are generated from the admin console and DNS TXT record “google._domainkey” must be created.

google._domainkey.definatelyarealcompany.com

TTL:

4 minutes 33 seconds

VALUE:

TXT

"v=DKIM1; k=rsa;
p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAhggj6NX0qcNG10xE94QdFwFgBAzQp76wCTb82sotS2TRj1l8tQdUiqgiuU+HE2/A2Z+OxxVlXAe0BqUsm8lYnogN6wXf62Ldr1o0pA562jzenEHZnQ/ME4CnlsZTfNKeGkBTdWhDUB4rHUGHCxYZzdMWaGHAo1+nISrgV8Y3gWys4zvK58ZfDPmLw/0SYTc"
"77xh4I7o9lejXnxU/joe/72B84i/zSaDnkwl9zeydLo/UKR5UEehqIXEFnjOnMMP6oScIWQzYxJuungpSijNDgWiRxlkmYvR63+RWrsOZJL19qDPwImUjmqP/FZo51tIJYY/OSqGxkXCDSb2QIDAQAB"

Gmail

Status

ON for everyone

DKIM authentication

The domains you select will use the DKIM (DomainKeys Identified Mail) protocol for authenticating outgoing emails. [Learn more](#)

Selected domain

definatelyarealcompany.com

Status: Authenticating email with DKIM.

You must update the DNS records for this domain.

To start authenticating email for the domain selected above, enter the following DNS TXT record into your domain provider's DNS settings page. Then click "Start authentication."

DNS Host name (TXT record name):

google._domainkey

TXT record value:

v=DKIM1; k=rsa;
p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAhggj6NX0qcNG10xE94QdFwFgBAzQp76wCTb82sotS2TRj1l8tQdUiqgiuU+HE2/A2Z+OxxVlXAe0BqUsm8lYnogN6wXf62Ldr1o0pA562jzenEHZnQ/ME4CnlsZTfNKeGkBTdWhDUB4rHUGHCxYZzdMWaGHAo1+nISrgV8Y3gWys4zvK58ZfDPmLw/0SYTc77xh4I7o9lejXnxU/joe/72B84i/zSaDnkwl9zeydLo/UKR5UEehqIXEFnjOnMMP6oScIWQzYxJuungpSijNDgWiRxlkmYvR63+RWrsOZJL19qDPwImUjmqP/FZo51tIJYY/OSqGxkXCDSb2QIDAQAB

GENERATE NEW RECORD

Figure 2.2.2.4&2.2.2.5 Google workplace RSA keys generation and DKIM configuration.

2.3 Domain-based Message Authentication, Reporting, and Conformance (DMARC)

DMARC provides a unified policy to handle emails that fail SPF or DKIM checks and report them to domain owner. DMARC also ensures the email “FROM” header aligns with the domain in SPF and DKIM checks, providing additional spoofing protection.

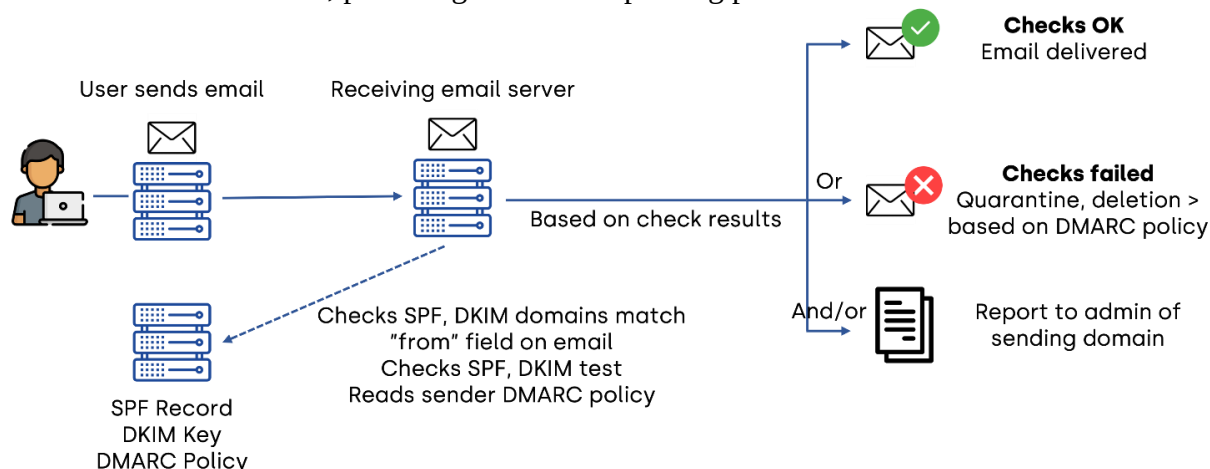


Figure 2.2.3.6 DMARC graph (Mantra, 2024).

A DMARC record usually contains the version of DMARC, policy to handle email failing SPF or DKIM and an email to send report to. Adding DMARC requires a DNS TXT record.

`_dmarc.definatelyarealcompany.com. IN TXT "v=DMARC1; p=none; rua=mailto:admin@definatelyarealcompany.com"`

Tên		<code>_dmarc.definatelyarealcompany.com</code>
TXT	TTL:	4 minutes 27 seconds
	VALUE:	"v=DMARC1; p=reject; rua=mailto:admin@definatelyarealcompany.com; pct=100; adkim=s; aspf=s"

Figure 2.2.3.7&2.2.3.8 Google workplace and mail server DMARC configuration.

2.4 Testing

```
Return-Path: notascammer@definitelyarealcompany.com
Received: from LAPTOP-8JM2RE67 (LAPTOP-8JM2RE67 [192.168.1.7])
    by LAPTOP-8JM2RE67 with ESMTPA
    ; Sat, 1 Jun 2024 14:50:42 +0700
From: <notascammer@definitelyarealcompany.com>
To: <Mr.s@definitelyarealcompany.com>
Subject: TEST
Date: Sat, 1 Jun 2024 14:50:42 +0700
Message-ID: <000001dab3f8$67087600$35196200$@definitelyarealcompany.com>
MIME-Version: 1.0
Content-Type: multipart/alternative;
    boundary="-----_NextPart_000_0001_01DAB433.1367C330"
X-Mailer: Microsoft Outlook 16.0
Thread-Index: Adqz+GUhkOghFC4rTkuC6dV9w5aaQQ==
Content-Language: en-us
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=definitelyarealcompany.com; s=default;
    h=From:To:Subject:Date:Message-ID:MIME-Version:Content-Type:X-Mailer:Thread-Index:Content-Language;
    bh=examplebhvalue;
    b=examplebvalue;
Received-SPF: pass (definitelyarealcompany.com: domain of notascammer@definitelyarealcompany.com designates
192.168.1.7 as permitted sender)
Authentication-Results: dmarc=pass header.from=definitelyarealcompany.com
```

No issues

No issues found for **definitelyarealcompany.com**
[Check another domain](#)

Anti-spoofing

- ✓ DMARC
- ✓ SPF
- ✓ DKIM

Email privacy

- ✓ TLS
- ✓ MTA-STS

Figure 2.2.4.1&2.2.4.2 Email domain scan and email headers.

Now, the company email domain will be scanned with a test email. Since, email security protocols are running, DMARC should trigger if the attacker tries to spoof the email domain.

```
This is the mail system at host emkei.cz.

I'm sorry to have to inform you that your message could not
be delivered to one or more recipients. It's attached below.

For further assistance, please send mail to postmaster.

If you do so, please include this problem report. You can
delete your own text from the attached returned message.

The mail system

<user@gmail.com>: host
gmail-smtp-in.l.google.com[142.251.8.27] said: 550-5.7.26 Unauthenticated
email from definitelyarealcompany.com is not accepted due to 550-5.7.26 domain's DMARC
policy. Please contact the administrator of 550-5.7.26 definitelyarealcompany.com domain
if this was a legitimate mail. To learn about 550-5.7.26 the DMARC
initiative, go to 550 5.7.26
https://support.google.com/mail/?p=DmarcRejection
41be03b00d2f7-6c359e075dfsi3069417a12.417 - gsmt (in reply to end of DATA
command)
```

```

Remote server replied: 550 SPF Sender Invalid - envelope rejected
Remote server replied: 550 DMARC Sender Invalid - envelope rejected
Remote server replied: 550 5.7.1 DMARC Authentication failed - domain
Remote server replied: 550 5.7.0 Email rejected per DMARC policy
Remote server replied: 550 5.7.0 Local Policy Violation - DMARC

```

Figure 2.2.4.3&2.2.4.4 DMARC prevents email spoofing.

3. Countermeasures against email phishing

To raise awareness against social engineering and spoofing emails, conduct regular training sessions on identifying suspicious emails, implement phishing simulations to test and educate employees. Make a policy requiring employees to verify sender addresses for every email and avoid clicking suspicious links. Furthermore, research also shows an automated solution to detect deception. (Abd, et al., 2021)

III) Phase 2: Scanning

1) Introduction

The second phase is scanning, where hackers examine open and closed ports to identify a potential entry point into the system. The hacker attempts to create a comprehensive overview of the target network including IP addresses or running services on systems.

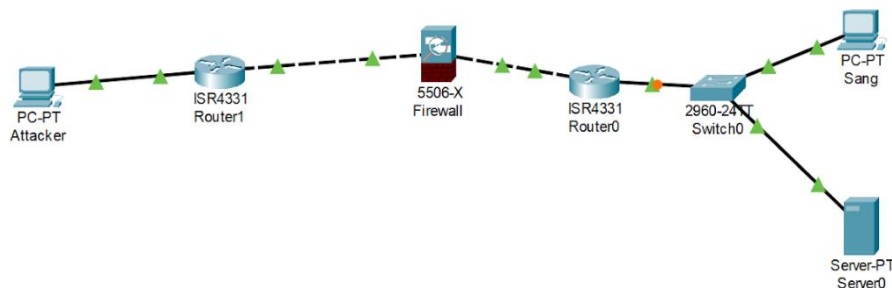


Figure 3.1.0.1: attacker trying to scan inside network

2) Firewall

To block access from an attacker, the defender must build and configure a firewall to stop access from the attacker. Here our team uses the IPTABLES as a method to block Nmap and ping or access from the attacker.

```

root@baozil-VirtualBox:~# sudo iptables -L --line-number
Chain INPUT (policy ACCEPT)
num target      prot opt source                destination             recent: CHECK seconds: 86400 name: portscan side: source mask: 25
1 DROP          all  -- anywhere              anywhere
5.255.255.255
2              all  -- anywhere              anywhere                recent: REMOVE name: portscan side: source mask: 255.255.255.255
3 LOG           tcp  -- anywhere              anywhere                tcp dpt:netbios-ssn recent: SET name: portscan side: source mask:
255.255.255.255 LOG level warning prefix "Portscan:"
4 DROP          tcp  -- anywhere              anywhere                tcp dpt:netbios-ssn recent: SET name: portscan side: source mask:
255.255.255.255
5 DROP          tcp  -- anywhere              anywhere                tcp flags:FIN,SYN/FIN,SYN
6 DROP          tcp  -- anywhere              anywhere                tcp flags:SYN,RST/SYN,RST
7 DROP          tcp  -- anywhere              anywhere                tcp flags:FIN,SYN,RST,PSH,ACK,URG/FIN,PSH,URG
8 DROP          tcp  -- anywhere              anywhere                tcp flags:FIN,SYN,RST,PSH,ACK,URG/FIN
9 DROP          tcp  -- anywhere              anywhere                tcp flags:FIN,SYN,RST,PSH,ACK,URG/NONE
10 DROP         tcp  -- anywhere              anywhere                tcp flags:FIN,SYN,RST,PSH,ACK,URG/FIN,SYN,RST,PSH,ACK,URG

Chain FORWARD (policy ACCEPT)
num target      prot opt source                destination             recent: CHECK seconds: 86400 name: portscan side: source mask: 25
1 DROP          all  -- anywhere              anywhere
5.255.255.255
2              all  -- anywhere              anywhere                recent: REMOVE name: portscan side: source mask: 255.255.255.255
3 LOG           tcp  -- anywhere              anywhere                tcp dpt:netbios-ssn recent: SET name: portscan side: source mask:
255.255.255.255 LOG level warning prefix "Portscan:"
4 DROP          tcp  -- anywhere              anywhere                tcp dpt:netbios-ssn recent: SET name: portscan side: source mask:
255.255.255.255

```

Figure 3.2.0.1

In both ‘chain INPUT’ and ‘FORWARD’, rules number 1 to 4 are for blocking port scan. Any attempt to conduct a port scan on our system will be automatically banned for a full 24-hour period. After the day has ended, delete them from the ports can list. Subsequently, these regulations include scanners in the port scan list and record the attempted action. For the rest rules of ‘chain INPUT’ will block TCP attacks which include SYN-FIN, SYN-RST, X-Mas, NULLflags, ALLflags attacks and nmap FIN scan.

```

(root@kali)-[~]
# nmap 192.168.1.103
Starting Nmap 7.94 ( https://nmap.org ) at 2024-06-02 12:24 EDT
Nmap scan report for 192.168.1.103
Host is up (0.00035s latency).
All 1000 scanned ports on 192.168.1.103 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 08:00:27:CF:F7:3F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 21.20 seconds

```

Figure 3.2.0.2

As an example, Nmap shows no-response means Nmap by an attacker has been blocked. On another example, when attack conduct specific port, it will show as filtered port (meaning a firewall or filter is blocking the port so that Nmap cannot tell whether it is open or closed):

```
(root@kali)-[~]
# nmap -p22 192.168.1.103
Starting Nmap 7.94 ( https://nmap.org ) at 2024-06-02 12:23 EDT
Nmap scan report for 192.168.1.103
Host is up (0.00031s latency).

PORT      STATE      SERVICE
22/tcp    filtered  ssh
MAC Address: 08:00:27:CF:F7:3F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.30 seconds
```

Figure 3.2.0.3

Beside that it can also block ping from the attacker:

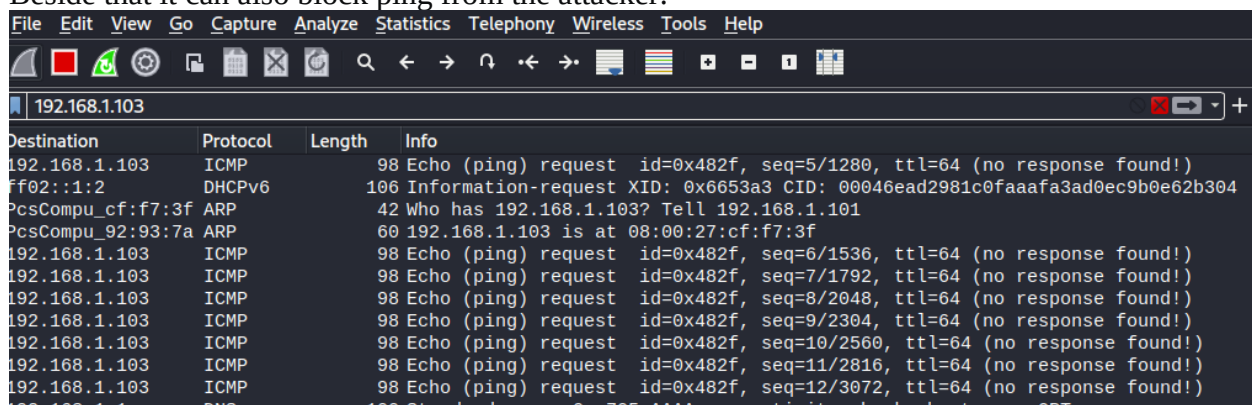


Figure 3.2.0.4

We also set some UDP rules to prevent UDP flood attacks:

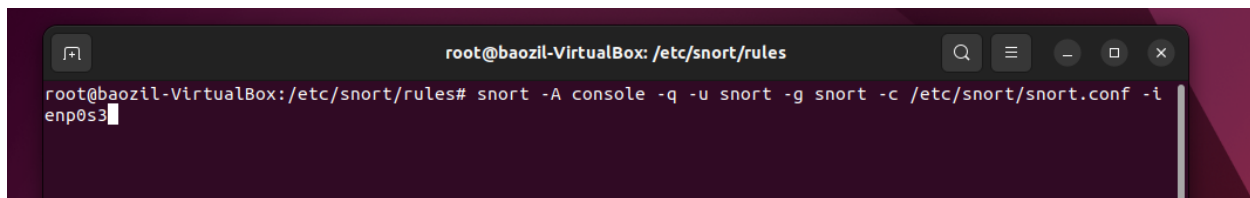
Chain udp-flood (1 references)				
num	target	prot	opt source	destination
1	RETURN	udp	-- anywhere	anywhere
2	LOG	all	-- anywhere	anywhere
3	DROP	all	-- anywhere	anywhere

limit: avg 50/sec burst 5
LOG level warning prefix "UDP-flood attempt: "

Figure 3.2.0.5

3) Snort

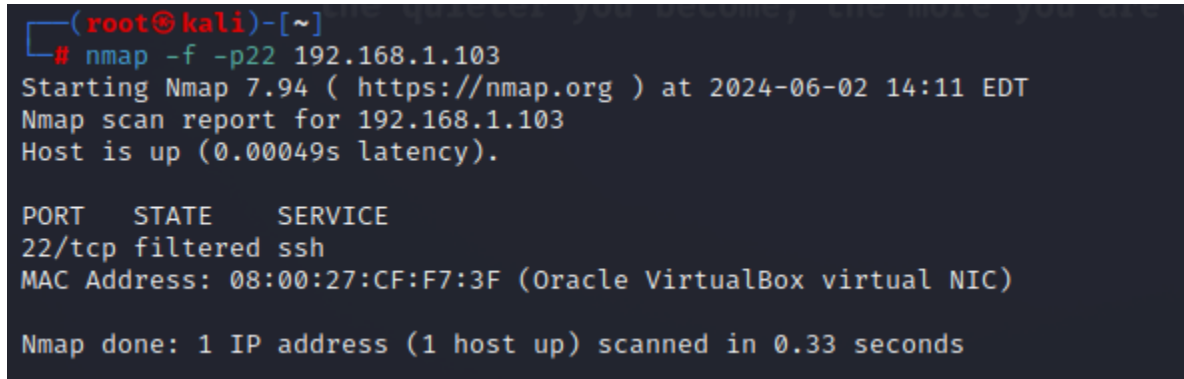
However, in certain cases, the attacker tries to bypass the firewall by fragmenting the Nmap packet. Therefore, we employ a network intrusion detection system known as Snort to prevent it. Snort employs a set of rules to identify and classify dangerous network activity (Snort.org, 2020). It then scans packets for matches against these rules and provides alerts for users. After installing and configuring Snort, we use a command to active Snort for recording attack and access from attackers:

A terminal window titled 'root@baozil-VirtualBox: /etc/snort/rules'. The command 'snort -A console -q -u snort -g snort -c /etc/snort/snort.conf -i enp0s3' has been entered and executed, resulting in a blank prompt.

```
root@baozil-VirtualBox: /etc/snort/rules# snort -A console -q -u snort -g snort -c /etc/snort/snort.conf -i enp0s3
```

Figure 3.3.0.1

In this situation, we use kali Linux as an attacker and try to do fragment Nmap to port 22 of ubuntu user:

A terminal window titled '(root@kali)-[~]'. The command 'nmap -f -p22 192.168.1.103' has been entered and executed. The output shows the Nmap scan report for 192.168.1.103, indicating that port 22/tcp is filtered and the host is up.

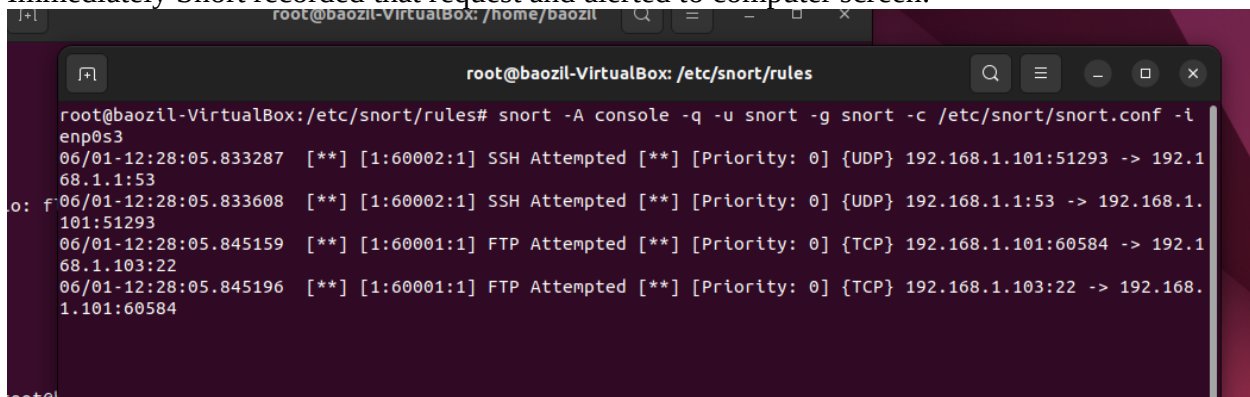
```
(root@kali)-[~]# nmap -f -p22 192.168.1.103
Starting Nmap 7.94 ( https://nmap.org ) at 2024-06-02 14:11 EDT
Nmap scan report for 192.168.1.103
Host is up (0.00049s latency).

PORT      STATE      SERVICE
22/tcp    filtered  ssh
MAC Address: 08:00:27:CF:F7:3F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.33 seconds
```

Figure 3.3.0.2

Immediately Snort recorded that request and alerted to computer screen:

A terminal window titled 'root@baozil-VirtualBox: /etc/snort/rules'. The command 'snort -A console -q -u snort -g snort -c /etc/snort/snort.conf -i enp0s3' has been entered and executed. The output shows several alerts for SSH and FTP attempts.

```
root@baozil-VirtualBox: /etc/snort/rules# snort -A console -q -u snort -g snort -c /etc/snort/snort.conf -i enp0s3
06/01-12:28:05.833287  [**] [1:60002:1] SSH Attempted [**] [Priority: 0] {UDP} 192.168.1.101:51293 -> 192.168.1.101:51293
06/01-12:28:05.833608  [**] [1:60002:1] SSH Attempted [**] [Priority: 0] {UDP} 192.168.1.101:51293 -> 192.168.1.101:51293
06/01-12:28:05.845159  [**] [1:60001:1] FTP Attempted [**] [Priority: 0] {TCP} 192.168.1.101:60584 -> 192.168.1.101:60584
06/01-12:28:05.845196  [**] [1:60001:1] FTP Attempted [**] [Priority: 0] {TCP} 192.168.1.101:60584 -> 192.168.1.101:60584
```

Figure 3.3.0.3

Figure 3.3.0.4 is the rule that we configure for Snort for detection.

```
root@baozil-VirtualBox: /home/baozil
GNU nano 6.2 /etc/snort/rules/local.rules
#alert tcp any any -> 192.168.1.103 22 (msg: "NMAP Fin"; flags:F; sid:108; rev:>
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
# -----
# LOCAL RULES
# -----
# This file intentionally does not come with signatures. Put your local
# additions here.

#alert icmp $EXTERNAL_NET any -> $HOME_NET any (msg: "NMAP attack"; sid:5889; rev: 1;)
alert tcp any any -> $HOME_NET any (msg:"FTP Attempted"; sid:60001; rev:1;)
alert udp any any -> $HOME_NET any (msg:"SSH Attempted"; sid:60002; rev:1;)
alert icmp any any -> $HOME_NET any (msg:"test"; sid:60003; rev:1;)
```

Figure 3.3.0.4

The format of each rule will include alert, protocol, external net, home net with the specific message and id. To get more specific alert, defender can configure rules to record:

```
root@baozil-VirtualBox: /home/baozil
GNU nano 6.2 /etc/snort/rules/local.rules
#alert tcp any any -> 192.168.1.103 22 (msg: "NMAP Fin"; flags:F; sid:108; rev:>
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
# -----
# LOCAL RULES
# -----
# This file intentionally does not come with signatures. Put your local
# additions here.

#alert icmp $EXTERNAL_NET any -> $HOME_NET any (msg: "NMAP attack"; sid:5889; rev: 1;)
#alert tcp any any -> $HOME_NET any (msg:"FTP Attempted"; sid:60001; rev:1;)
#alert udp any any -> $HOME_NET any (msg:"SSH Attempted"; sid:60002; rev:1;)
#alert icmp any any -> $HOME_NET any (msg:"NMAP ping sweep"; sid:60003; rev:1;)

alert icmp any any -> 192.168.1.103 any (msg: "NMAP ping sweep"; sid:5889; rev: 1;)
alert tcp any any -> 192.168.1.103 22 (msg: "NMAP TCP"; sid:105; rev: 1;)
alert tcp any any -> 192.168.1.103 22 (msg: "NMAP XMAS Tree"; flags:FPU; sid:107; rev: 1;)
alert tcp any any -> 192.168.1.103 22 (msg: "NMAP Fin"; flags:F; sid:108; rev: 1;)
alert tcp any any -> 192.168.1.103 22 (msg: "NMAP NULL"; flags:0; sid:109; rev:1;)
alert udp any any -> 192.168.1.103 any (msg: "NMAP UDP"; sid:110; rev:1; )
```

Figure 3.3.0.5

Here are some basic rules that record TCP, Xmas, FIN attacks or UDP. For example, we can do -sU and -sX

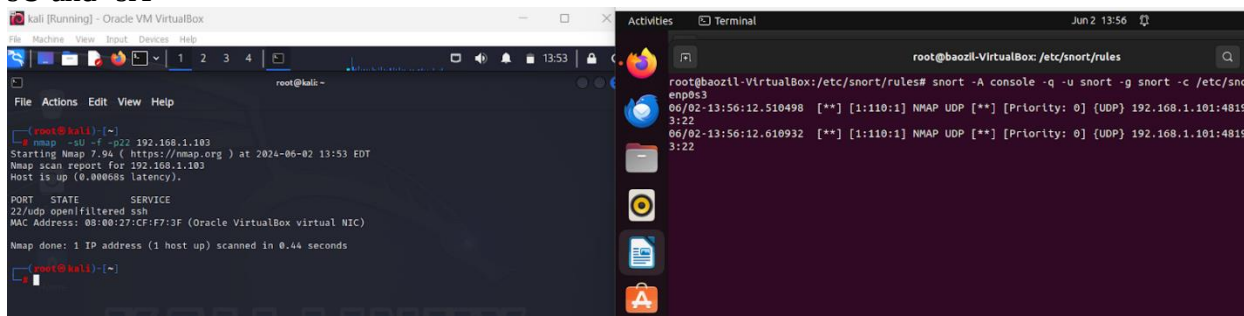


Figure 3.3.0.6: *nmap -sU -f*

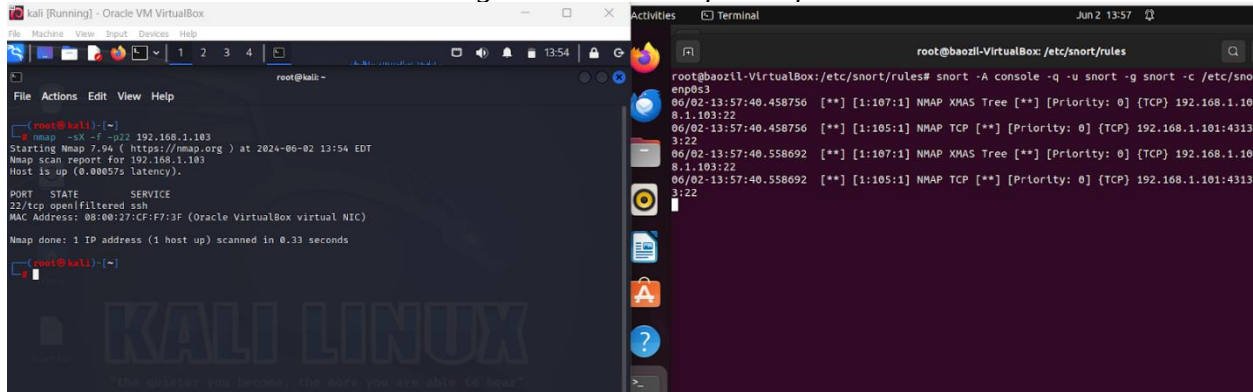


Figure 3.3.0.7 *nmap -sX -f*

Immediately Snort recorded -sU as “NMAP UDP” alert and -sX as “XMAS TREE” and “NMAP TCP” alert.

IV) Phase 3: Gaining access

1. Incident Report:

After investigating the incident, we found that the username “Sang” have run a malware name “Not a Malware”, and that give the access to the attacker

Jun 3, 2024 @ 17:58:09.440	file.name	Not a Malware	file.path	C:\Users\God\Downloads\Not a Malware	@timestamp	Jun 3, 2024 @ 17:58:09.440	agent.id	feeb99cd-6340-4b13-ab3b-81e2dd2e2093	agent.type	endpoin
	t agent.version	8.13.4	data_stream.dataset	endpoint.events.file	data_stream.namespace	default	data_stream.type	logs	ecs.version	8.10.0
	elastic.agent.id	feeb99cd-6340-4b13-ab3b-81e2dd2e2093	event.action	rename	event.agent_id.status	verified	event.category	file	event.created	Jun 3, 2024 @ 17:58:09.440
	event.dataset	endpoint.events.file	event.id	NZqVOT...						

Figure 4.1.0.1.: Elastic show that user “Sang” run “Not a Malware”

After interrogating the employee “Sang”, we learn that the malware entered the system through phishing email. To stop the spread of the malware, we pinpoint all the end-devices that were affected by the malware and isolate them. After that, we download the malware to a sandbox to further analyze it.

2. Attack vectors analyze:

1. Dynamic analyzes:

1. Tool use in this phase

Regshot

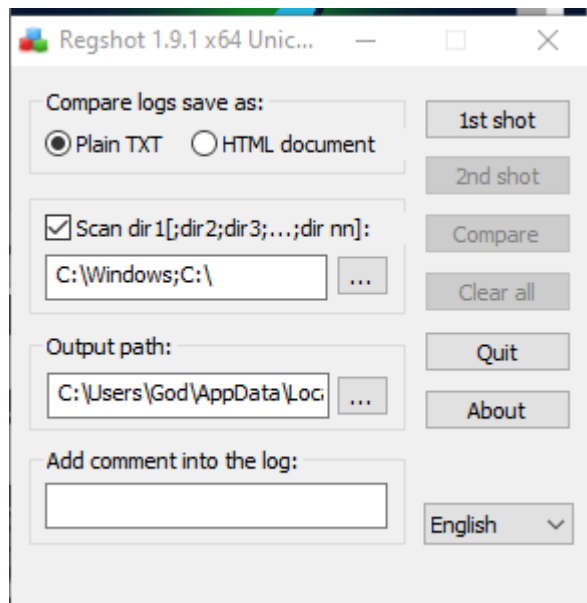


Figure 4.2.1.1: The regshot tool

Regshot is an open-source (LGPL) registry compare utility that allows you to quickly take a snapshot of your registry and then compare it with a second one (Sudhir, 2014)

2.1.2 Conducting analyze:

We take a snapshot of the machine before running the malware.

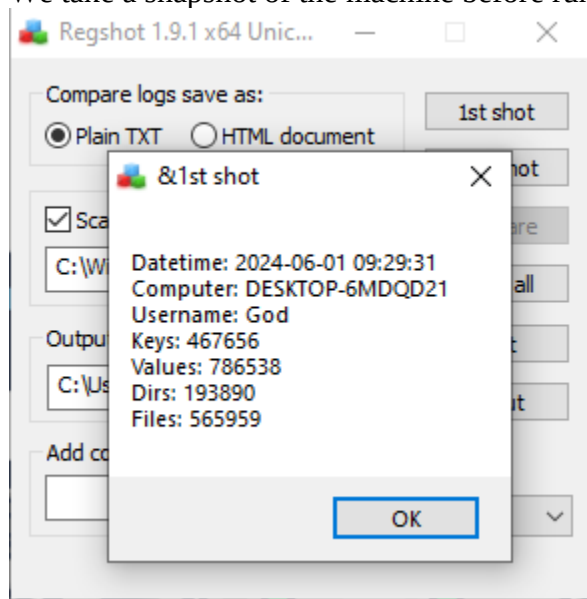


Figure 4.2.1.2: Taking the 1st snapshot

After the snapshot, we ran the malware that had infected our system name “Not a Malware”.

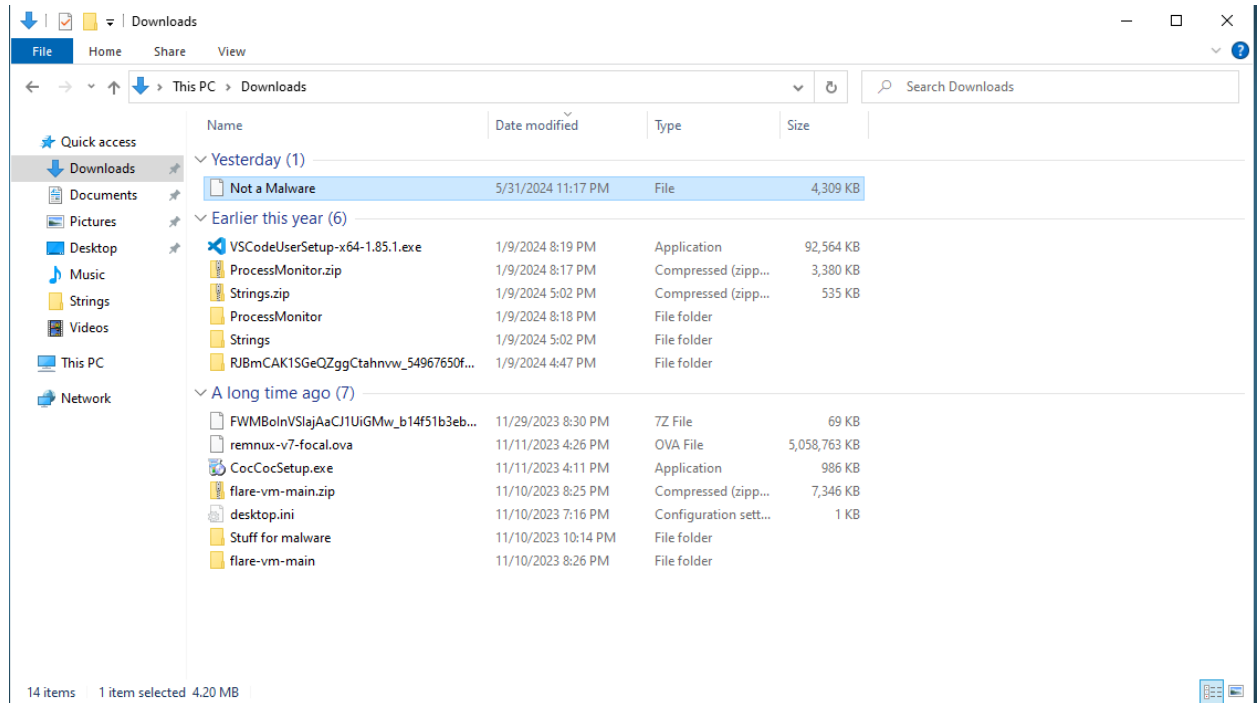


Figure 4.2.1.3: The “Not a Malware” malware

When the malware finishes running, we take the second snapshot of the machine and then compare them.

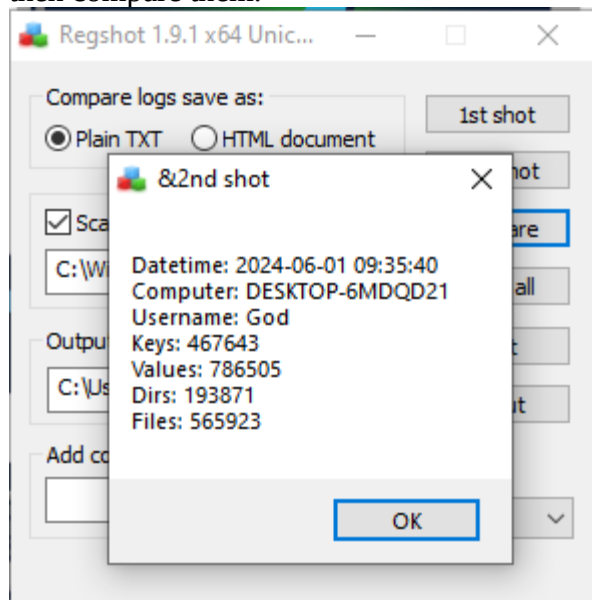


Figure 4.2.1.4: Taking the 2nd snapshot

```
~res-x64.txt - Notepad
File Edit Format View Help
Regshot 1.9.1 x64 Unicode (beta r321)
Comments:
Datetime: 2024-06-01 09:29:31, 2024-06-01 09:35:40
Computer: DESKTOP-6MDQD21, DESKTOP-6MDQD21
Username: God, God

-----
Keys deleted: 19
-----
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\10188
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\1836
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\2300
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\2596
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\3028
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\3848
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\3936
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\4372
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\4432
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\4936
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\5716
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\696
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\7224
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\8232
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\9124
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\9204
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\9768
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\9804
HKLM\SOFTWARE\Microsoft\Windows\Windows Error Reporting\TermReason\9912

-----
Keys added: 6
-----
HKLM\SOFTWARE\Microsoft\IdentityCRL\NegativeCache\0018800C0ACD71BC_5-1-5-21-4138450363-2843389885-839799607-1001_{67082621-8D18-4333-9C64-10DE93676363}
HKLM\SOFTWARE\Microsoft\IdentityCRL\NegativeCache\0018800C0ACD71BC_5-1-5-21-4138450363-2843389885-839799607-1001_{67082621-8D18-4333-9C64-10DE93676363}\https://watson.telemetry
HKLM\SOFTWARE\Microsoft\IdentityCRL\ThrottleCache\5-1-5-21-4138450363-2843389885-839799607-1001_{67082621-8D18-4333-9C64-10DE93676363}
HKU\S-1-5-21-4138450363-2843389885-839799607-1001\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\SessionInfo\1\ApplicationViewManagement\WRT:Microsoft.Windows.SecHealthUI_
HKU\S-1-5-21-4138450363-2843389885-839799607-1001\SOFTWARE\Microsoft\Windows\CurrentVersion\Internet Settings\5.0\Cache\FriendlyName\Cache\MSHIC+01707D06A1707D06A2
Ln 1, Col 1 100% Windows (CRLF) UTF-16 LE
```

Figure 4.2.1.5: The output of the comparison

Compared to the first snapshot, the second have: 19 deleted keys, 6 keys were added, 58 values were deleted, 25 values were added, 120 values were modified, 23 folders deleted, 4 folders added, 63 files deleted, 27 files added, 169 files attributes modified.

2. Static analyzes:

2.2.1 Tool use in this phase:

DIE

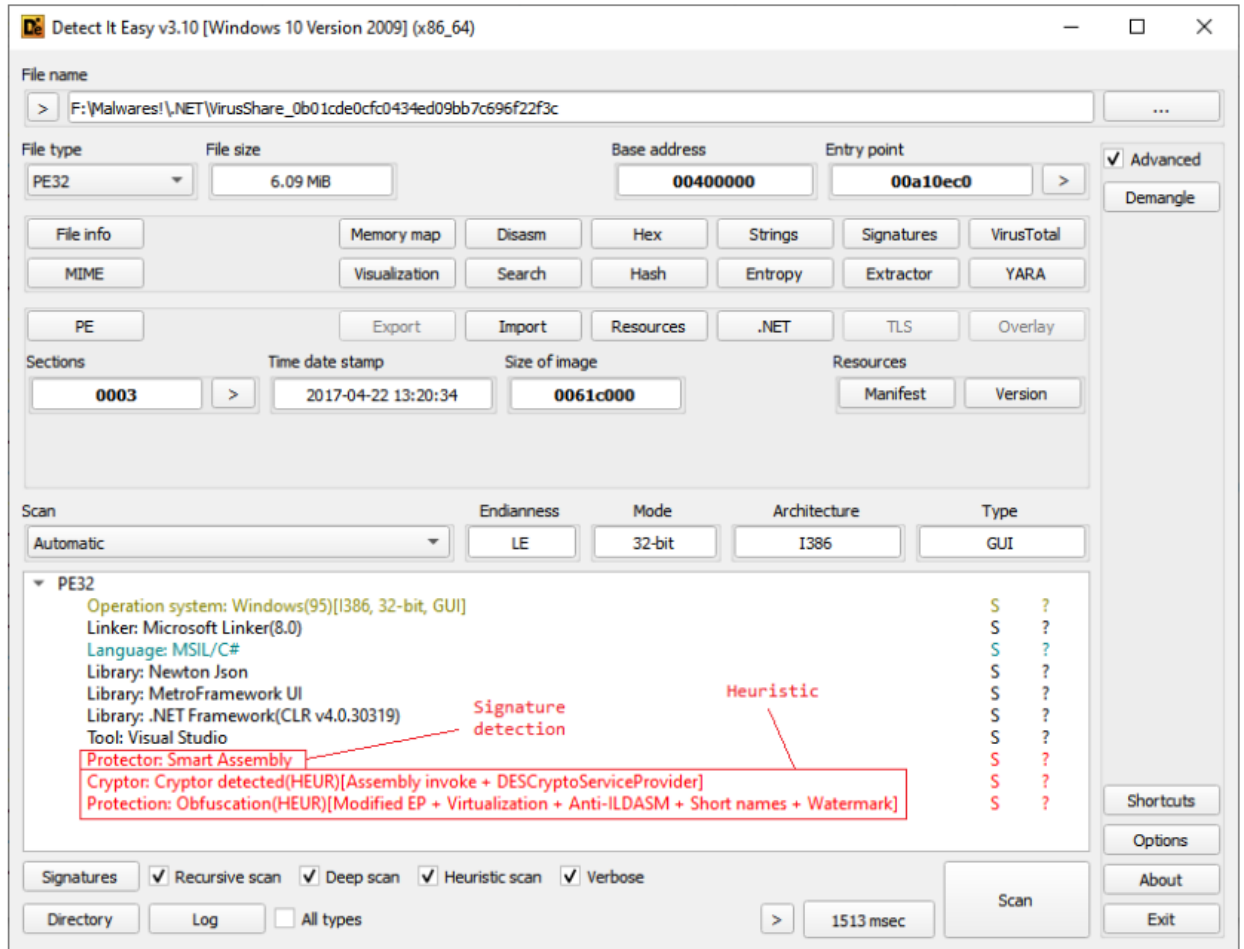


Figure 4.2.2.1: DIE tool

Detect it easy or DIE is a tool used to identify the types of files.

HxD

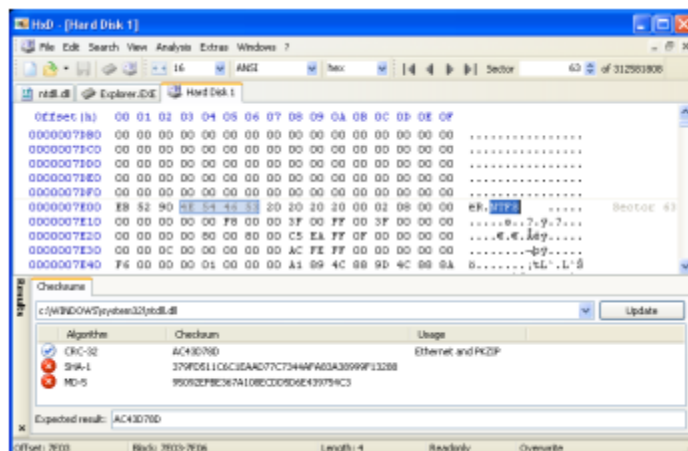


Figure 4.2.2.2: HxD tool

HxD is a freeware hex editor, disk editor, and memory editor which can open files, edit the raw contents of disk drives, display and edit the memory used by running processes. (A, Monnappa, 2024)

2.2.2. Conducting analyzes:

The first step is to identify the file type of the malware by using DIE.

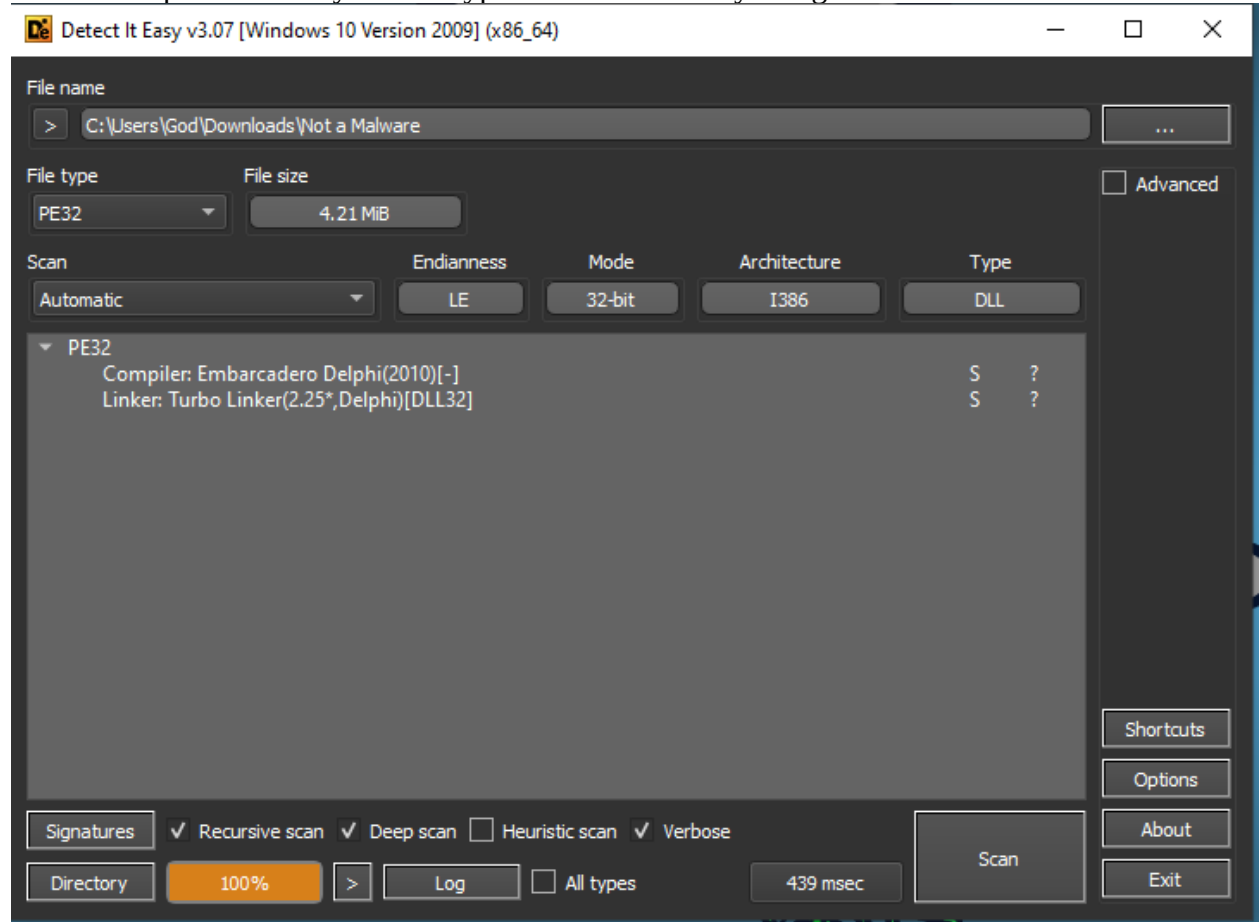


Figure 4.2.2.1: DIE detecting the malware

After running it in DIE, we learn that this malware type is DLL and it runs in PE32, which shows that the sample is from a 32-bit DLL file.

To understand more about the malware, we then use HxD to read its hex value.

File Edit Search View Analysis Tools Window Help

[illegible]

Figure 4.2.2.3: Payload after the loop values

When scrolling down, we seem to find the payload of the malware. For further investigation and finding ways to prevent this malware in the future, we use strings command on the malware to see what strings it might contain.

```
Invalid variant operation
Invalid NULL variant operation%Invalid variant operation (%s%.8x)
%s,Custom variant type (%s%.4x) is out of range/Custom variant type (%s%.4x) already used by %s*Custom variant type (%s%.4x)
e (%s)=Overflow while converting variant of type (%s) into type (%s)
Variant overflow
Invalid argument
Invalid variant type
Operation not supported
Unexpected variant error
External exception %x
Assertion failed
Access violation at address %p. %s of address %p
Access violation
Stack overflow
Control-C hit
Privileged instruction(Exception %s in module %s at %p.
%s)s
Application Error!Format '%s' invalid or incompatible with argument
No argument for format '%s'"Variant method calls not supported
Read
Write$Error creating variant or safe array)Variant or safe array index out of bounds
Variant or safe array is locked
Invalid variant type conversion
Out of memory
I/O error %d
Too many open files
```

Figure 4.2.2.4: The strings of the malware using strings command

Looking at the strings, we can 100% confirm this malware is trying a buffer overflow attack on our machine by attempting to access the Registry.

3. Migration:

1. Tool use in this phase:

Yara:

YARA is a powerful pattern-matching tool and rule format used for identifying and classifying files based on specific patterns, characteristics, or content. SOC analysts commonly use YARA rules to detect and classify malware samples, suspicious files, or indicators of compromise (IOCs).

Elastic stack:

The Elastic stack, created by Elastic, is an open-source collection of mainly three applications (Elasticsearch, Logstash, and Kibana)that used for comprehensive search and visualization of log file sources.

2. Implement migration:

To prevent this malware in the future, we must create the Yara rule by identifying strings that are in the malware. After that, we create a Yara rule:

```

rule buffer_overflow_detector {
meta:
    description = "rule that detects possible buffer overflow attack in DLL file"
strings:
    $a01 = "This program must be run under Win32"
    $a02 = "FastMM Borland Edition (c) 2004 - 2008 Pierre le Riche / Professional
Software Development"
    $a03 = "An unexpected memory leak has occurred."
    $a04 = "Access violation at address %p. %s of address %p"
    $a05 = "Integer overflow Invalid floating point operation"
    $a06 = "The unexpected small block leaks are"
    $a07 = "kernel32.dll"
    $a08 = "Software\CodeGear\Locales = Software\
Borland\Locales = Software\Borland\Delphi\Lo
cales"
    $a09 = "RegUnLoadKey"
    $a10 = "RegSetValueEx"
    $a11 = "RegSaveKey"
    $a12 = "RegRestoreKey"
    $a13 = "RegReplaceKey"
    $a14 = "RegQueryValueEx"
    $a15 = "RegQueryInfoKey"
    $a16 = "RegOpenKeyEx"
    $a17 = "RegLoadKey"
    $a18 = "RegFlushKey"
    $a19 = "RegEnumValue"
    $a20 = "RegEnumKeyEx"
    $a21 = "RegDeleteValue"
    $a22 = "RegDeleteKey"
    $a23 = "RegCreateKeyEx"
    $a24 = "RegConnectRegistry"
    $a25 = "RegCloseKey"
    $a26 = {4D 5A}
condition:
    (all of $a*)
}

```

Figure 4.3.2.1: Yara rule

Finally, we apply the Yara rule to elastic so whenever this type of malware enters the system, we can detect and prevent it

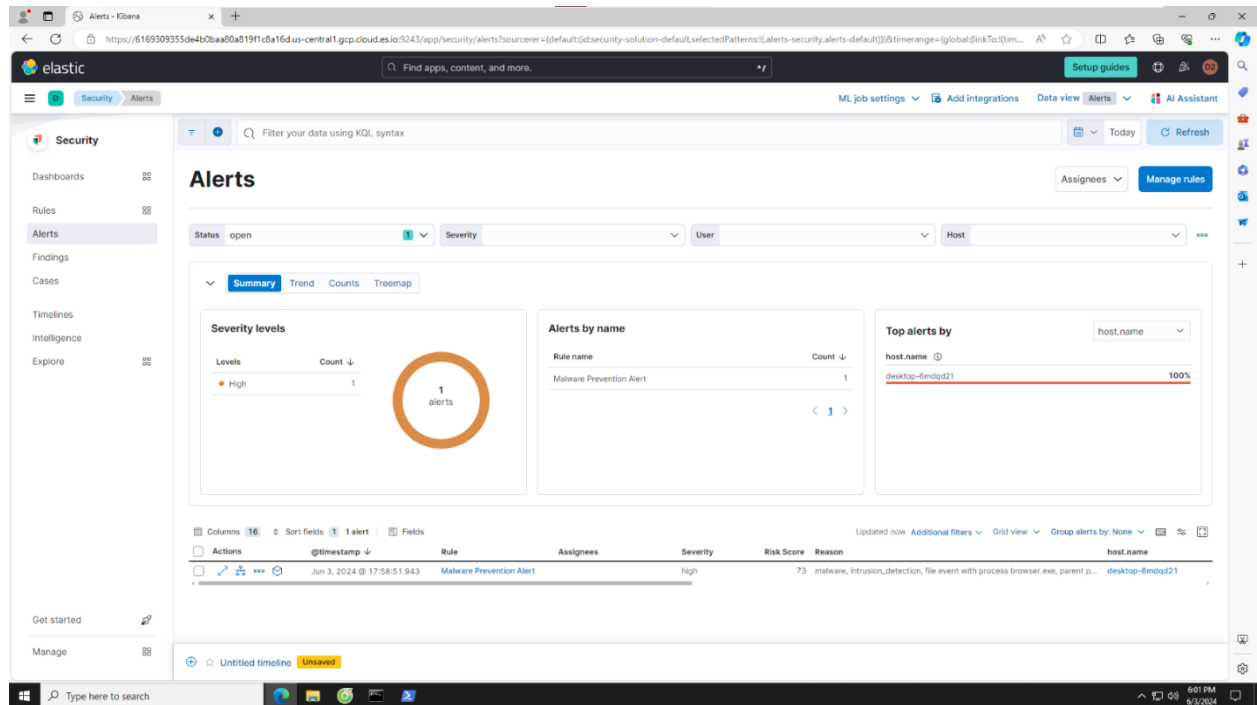


Figure 4.3.2.2: Elastic block and alert the malware

V) Phase 4: Maintaining Access

1. Attack technique

In this phase, the attacker aims to maintain persistent access to the compromised system. By leveraging SSH (Secure Shell) techniques, the attacker configures SSH configuration to disable password authentication and enable public key authentication.

```

GNU nano 6.2                               /etc/ssh/sshd_config *
PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile      .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication no
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with

```

figure 5.1.0.1: sshd configuration

The attacker generates an SSH key pair, placing the public key in the system's authorized keys file.

```

root@ubuntu-VirtualBox:/home/ubuntu# ssh-keygen
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa):
/root/.ssh/id_rsa already exists.
Overwrite (y/n)? y
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_rsa
Your public key has been saved in /root/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:d70lftHbps2eOhvJ3jWq/H5kbMInZnI+9MpXnvVwgy root@ubuntu-VirtualBox
The key's randomart image is:
+--[RSA 3072]--+
|
|      E . . |
|    S . + =.o|
|    . o.%o@B|
|    O+@*@|
|    . o++@*|
|    o+XX++|
+--[SHA256]--+
root@ubuntu-VirtualBox:/home/ubuntu# █

```

figure 5.1.0.2: rsa generation

Then the attacker can add his private key to the system, or he can change the value of existing private key to his private key value to guarantee no-one can access except him.

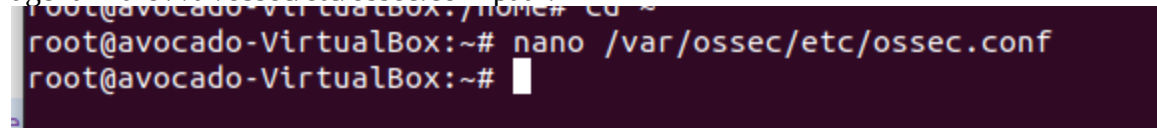
2. Wazuh introduction

Therefore, we introduce Wazuh as a solution for detecting and responding for the persistence threats. Wazuh is an open-source security platform that includes XDR and SIEM capabilities. Like Elastic, Wazuh collects events from the agents or network devices, then forwards them to the server to check matched events or alerts. (Wazuh, 2024)

3. Demonstration

3.1) SSH backdoor prevention

To prevent attackers from gaining backdoor through SSH protocol, we need to configure file and directory integrity of .ssh directory and sshd_config file in Wazuh, so any changes will be alert to SOC team to investigate closer. Firstly, we need to edit the Wazuh configuration file of the agent in the /var/ossec/etc/ossec.conf path.

A terminal window with a dark purple background. The prompt is 'root@avocado-VirtualBox:~#'. The command 'nano /var/ossec/etc/ossec.conf' has been entered, and the cursor is at the end of the line.

```
root@avocado-VirtualBox:~# nano /var/ossec/etc/ossec.conf
root@avocado-VirtualBox:~#
```

figure 5.3.1.1: edit ossec.conf

```

GNU nano 6.2 /var/ossec/etc/ossec.conf *
<!--
Wazuh - Manager - Default configuration for ubuntu 22.04
More info at: https://documentation.wazuh.com
Mailing list: https://groups.google.com/forum/#!forum/wazuh
-->

<ossec_config>
  <global>
    <jsonout_output>yes</jsonout_output>
    Rhythmbox <log>yes</alerts_log>
    <logall>no</logall>
    <logall_json>no</logall_json>
    <email_notification>no</email_notification>
    <smtp_server>smtp.example.wazuh.com</smtp_server>
    <email_from>wazuh@example.wazuh.com</email_from>
    <email_to>recipient@example.wazuh.com</email_to>
    <email_maxperhour>12</email_maxperhour>
    <email_log_source>alerts.log</email_log_source>
    <agents_disconnection_time>10m</agents_disconnection_time>
    <agents_disconnection_alert_time>0</agents_disconnection_alert_time>
  </global>

  <alerts>
    <log_alert_level>3</log_alert_level>
    <email_alert_level>12</email_alert_level>
  </alerts>

  <!-- Choose between "plain", "json", or "plain,json" for the format of internal logs -->
  <logging>
    <log_format>plain</log_format>
  </logging>

  <remote>
    <connection>secure</connection>
    <port>1514</port>
    <protocol>tcp</protocol>
    <queue_size>131072</queue_size>
  </remote>

  <!-- Policy monitoring -->
  <rootcheck>
    <disabled>no</disabled>
    <check_files>yes</check_files>
    <check_trojans>yes</check_trojans>

```

figure 5.3.1.2: Wazuh agent configuration

Then we write the alert rule by specifying the folder that we are going to monitor for changes which is `.ssh` in this case.

```

<!-- Directories to check (perform all possible verifications) -->
<directories>/etc,/usr/bin,/usr/sbin</directories>
<directories>/bin,/sbin,/boot</directories>
<directories realtime="yes">/home/avocado/.ssh</directories>

```

figure 5.3.1.3: Adding rules send alert to Wazuh manager

After that, to make the wazuh server display on the dashboard, we need to write the event information like id, rules, messages on the `local_rule.xml`

```
<group name="syscheck,pci_dss_11.5,nist_800_53_SI.7,">
  <!-- Rules for Linux systems -->
  <rule id="100200" level="7">
    <if_sid>550</if_sid>
    <field name="file">/home/ubuntu/.ssh</field>
    <description>File modified in /home/ubuntu/.ssh directory.</description>
  </rule>
  <rule id="100201" level="7">
    <if_sid>554</if_sid>
    <field name="file">/home/ubuntu/.ssh</field>
    <description>File added to /home/ubuntu/.ssh directory.</description>
  </rule>
</group>
```

figure 5.3.1.4: Adding rules to display alert on Wazuh manager

Finally, we are going to test the alert by adding, modifying and removing the key in .ssh folder, which is the attacker's technique to maintain persistence in the system.

```
root@ubuntu-VirtualBox:/home/ubuntu/.ssh# nano id_rsa2
root@ubuntu-VirtualBox:/home/ubuntu/.ssh# echo "hello" >> id_rsa2
root@ubuntu-VirtualBox:/home/ubuntu/.ssh# rm -rf id_rsa2
root@ubuntu-VirtualBox:/home/ubuntu/.ssh#
```

figure 5.3.1.5: Testing on agent

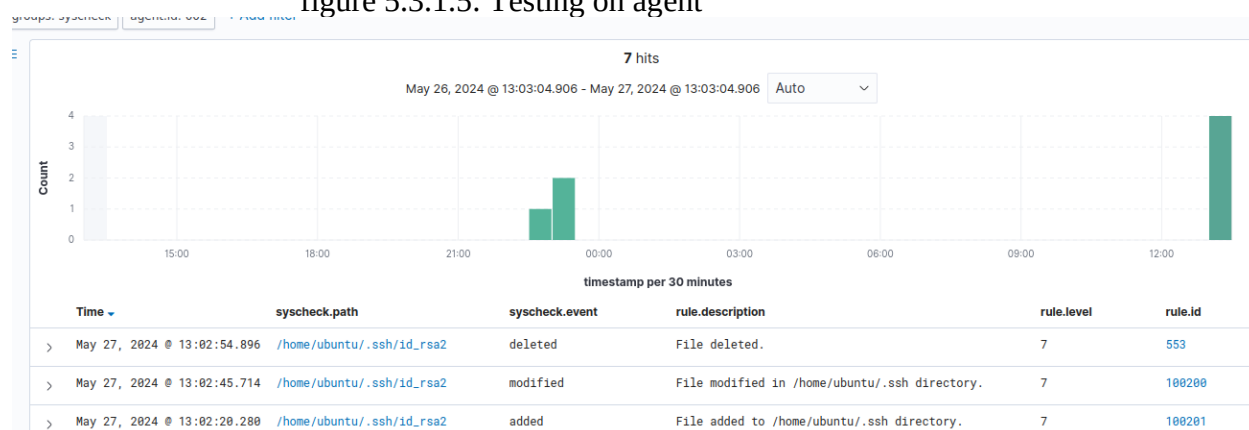


figure 5.3.1.6: Dashboard alert

The figure 5.3.1.6 demonstrates changes in .ssh file can result in the alerts in Wazuh as we configured before. By following these steps, we are going to configure the same with the sshd_config file, then we can totally detect attacker presence in the system.

3.2) MITRE ATT&CK detection

Thanks to the integration with MITRE ATT&CK, Wazuh can reduce the process by generating alerts corresponding to the attacker techniques in MITRE framework. For the demonstration, we are going to use Invoke –atomic red team which is the tool that automatically replicates red team's techniques in the MITRE framework, then we are going to use Wazuh to detect it. Firstly, install the Invoke Atomic.

```
root@ubuntu-virtualbox:/home/ubuntu/.ssh# pwsn
PowerShell 7.4.2
PS /home/ubuntu/.ssh> IEX (IWR 'https://raw.githubusercontent.com/redcanaryco/invoke-atomicredteam/master/install-atomicredteam.ps1' -UseBasicParsing);
```

figure 5.3.2.1: Install Invoke Atomic

After that, choose any technique from MITRE then execute it in the program. The technique that we chose is T1548.003 which is privilege escalation and defense evasion tactic.

```
Done executing test: T1548.003-6 Disable tty_tickets for sudo caching (freebsd)
PS /home/ubuntu> Invoke-AtomicTest T1548.003
PathToAtomicFolder = /root/AtomicRedTeam/atomics

Executing test: T1548.003-1 Sudo usage
Matching Defaults entries for root on ubuntu-VirtualBox:
    env_reset, timestamp_timeout=-1, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty, !tty_tickets, !tty_tickets
User root may run the following commands on ubuntu-VirtualBox:
    (ALL : ALL) ALL
#
# This file MUST be edited with the 'visudo' command as root.
#
# Please consider adding local content in /etc/sudoers.d/ instead of
# directly modifying this file.
#
# See the man page for details on how to write a sudoers file.
#
Defaults      env_reset,timestamp_timeout=-1
Defaults      mail_badpass
Defaults      secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/
```

figure 5.3.2.2: result of executing Invoke-Atomic

We can see the sudoers file with its configuration after executing this tactic. Now, we are going to check Wazuh's alert and event.

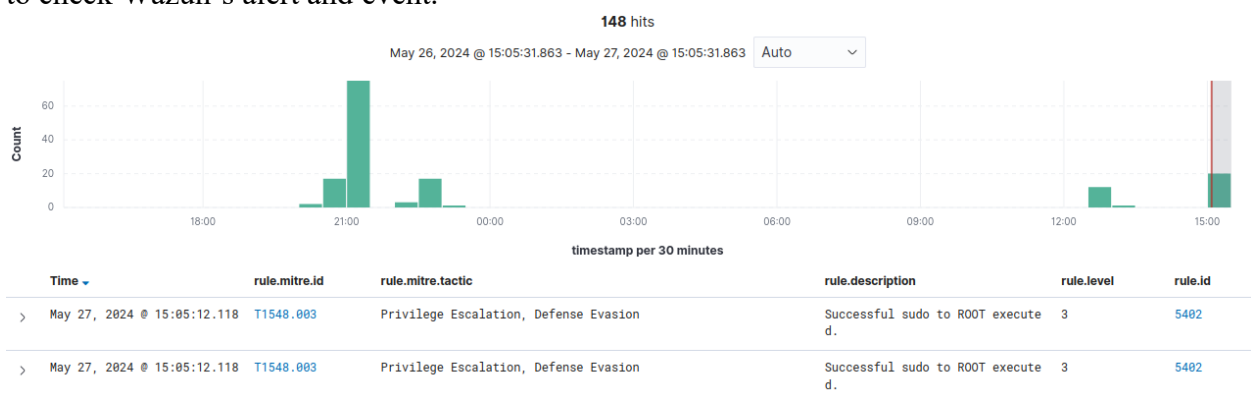


figure 5.3.2.3: Alert of T1548.003

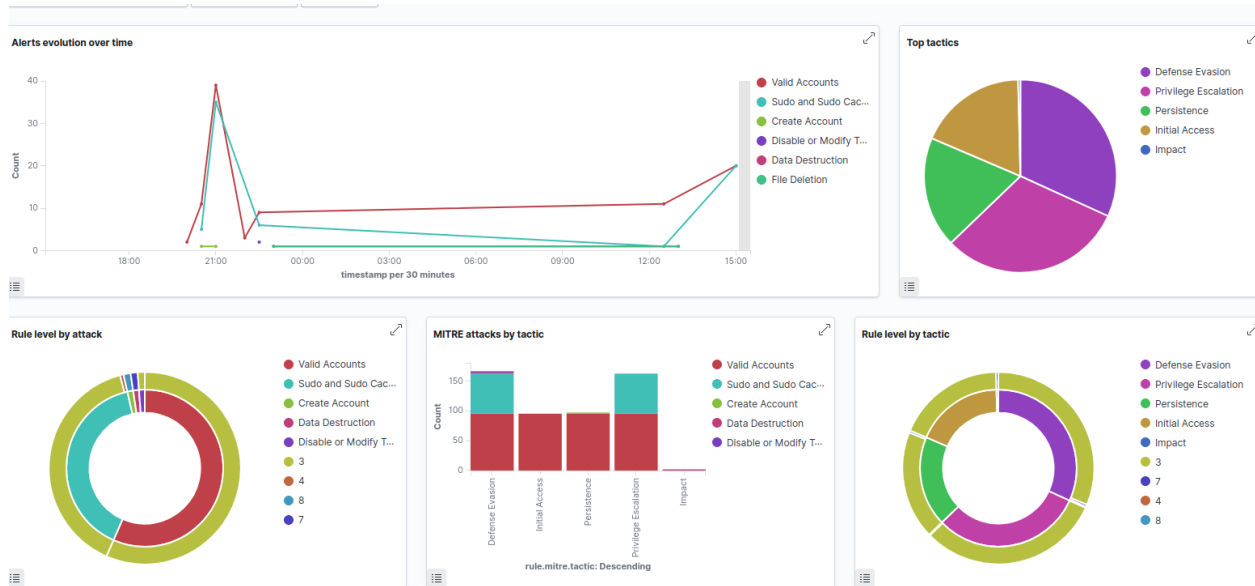


figure 5.3.2.4: dashboards of detected techniques

As we can see, Wazuh not only successfully detects the event, but it also visualizes data for all detected tactics.

VI) Phase 5: Prevention of clearing tracks

1) What is the clearing track phase?

After maintaing access, hacker can delete log files if the system has not set privileges correctly.

2) Solution for prevent clearing track

2.1) Solution 1: A real-time log file alert via email from the agent (Wazuh).

Step 1: setup wazuh real-time email alert with SMTP server with authentication

1. Mail server configuration type setup.

Command: `apt-get update && apt-get install postfix mailutils libsasl2-2 ca-certificates libsasl2-modules`

2. Configure Postfix server relay in `/etc/postfix/main.cf` directories.

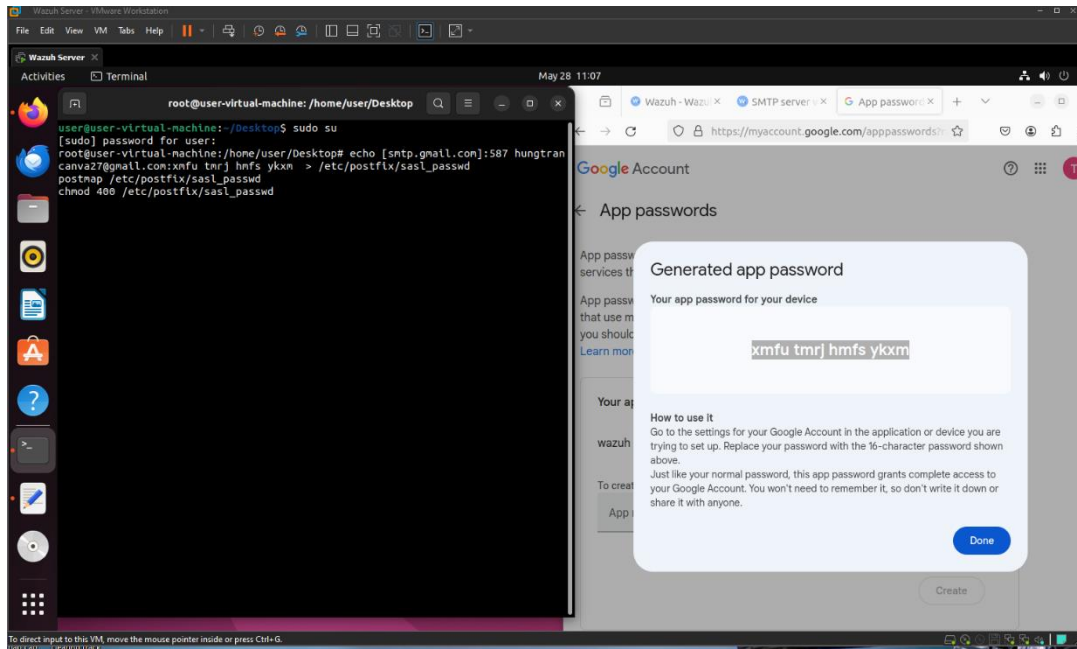


Figure 6.2.1.1

3. Set sender email address and password.

In this step, we configure using Gmail host to send the Gmail, so we need to use Google APP password.

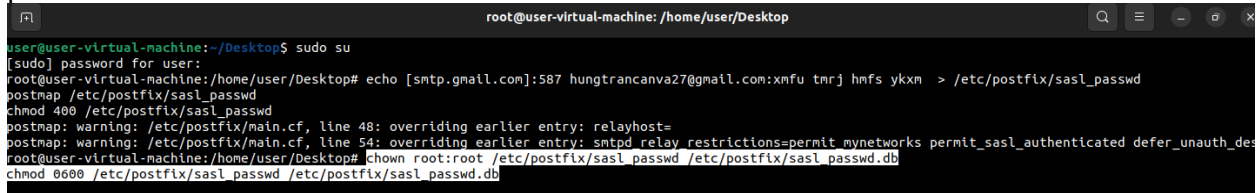


Figure 6.2.1.2

4. Secure password DB file to only root user has privileges.

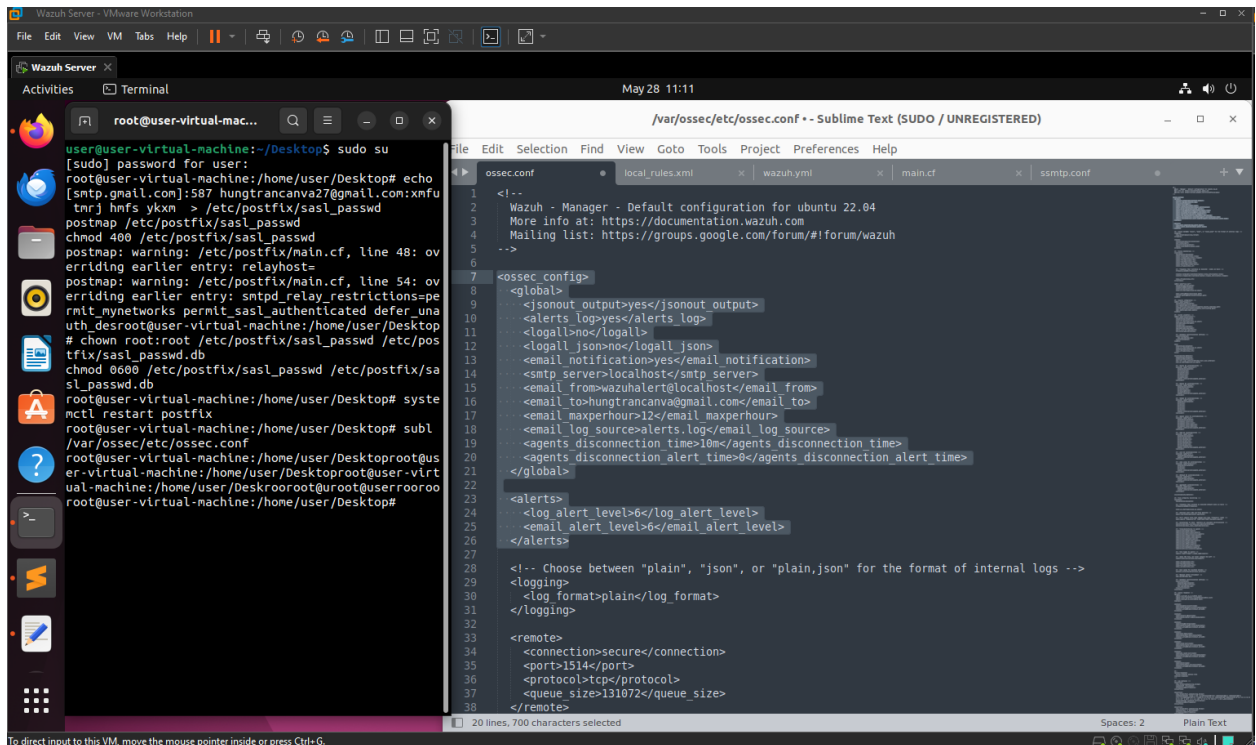


Figure 6.2.1.3

5. Restart Postfix.
- Command: `sudo systemctl restart PostFix`
6. Configure email notifications in Wazuh server.

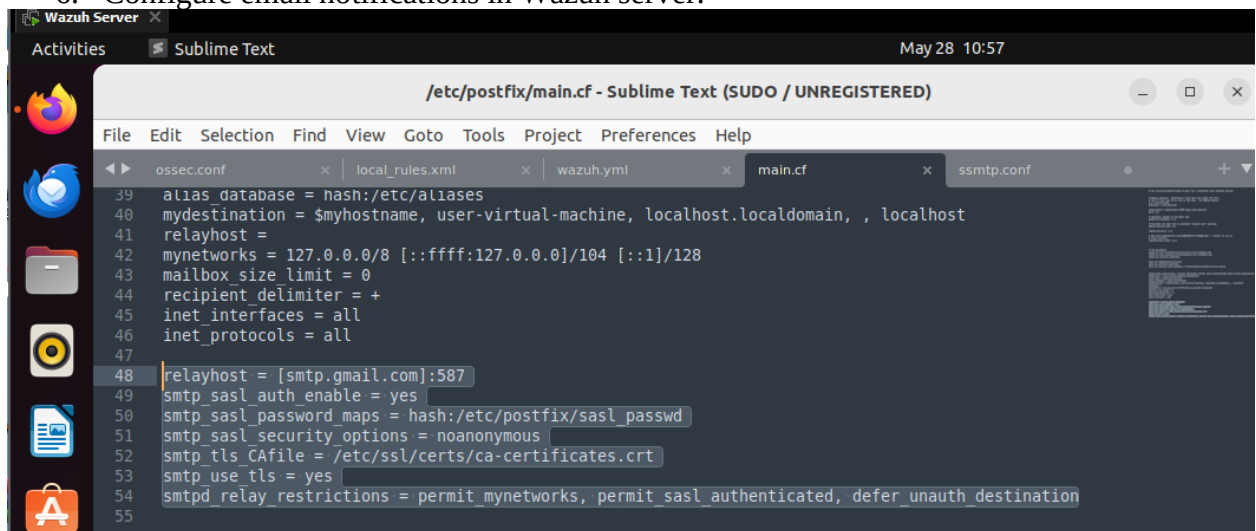


Figure 6.2.1.4

Step 2: Configure <syscheck> on Wazuh Agent side.

1. Open configuration file
- Command: `subl nano /var/ossec/etc/ossec.conf`
2. Add on <syscheck> section to monitor desire log file.

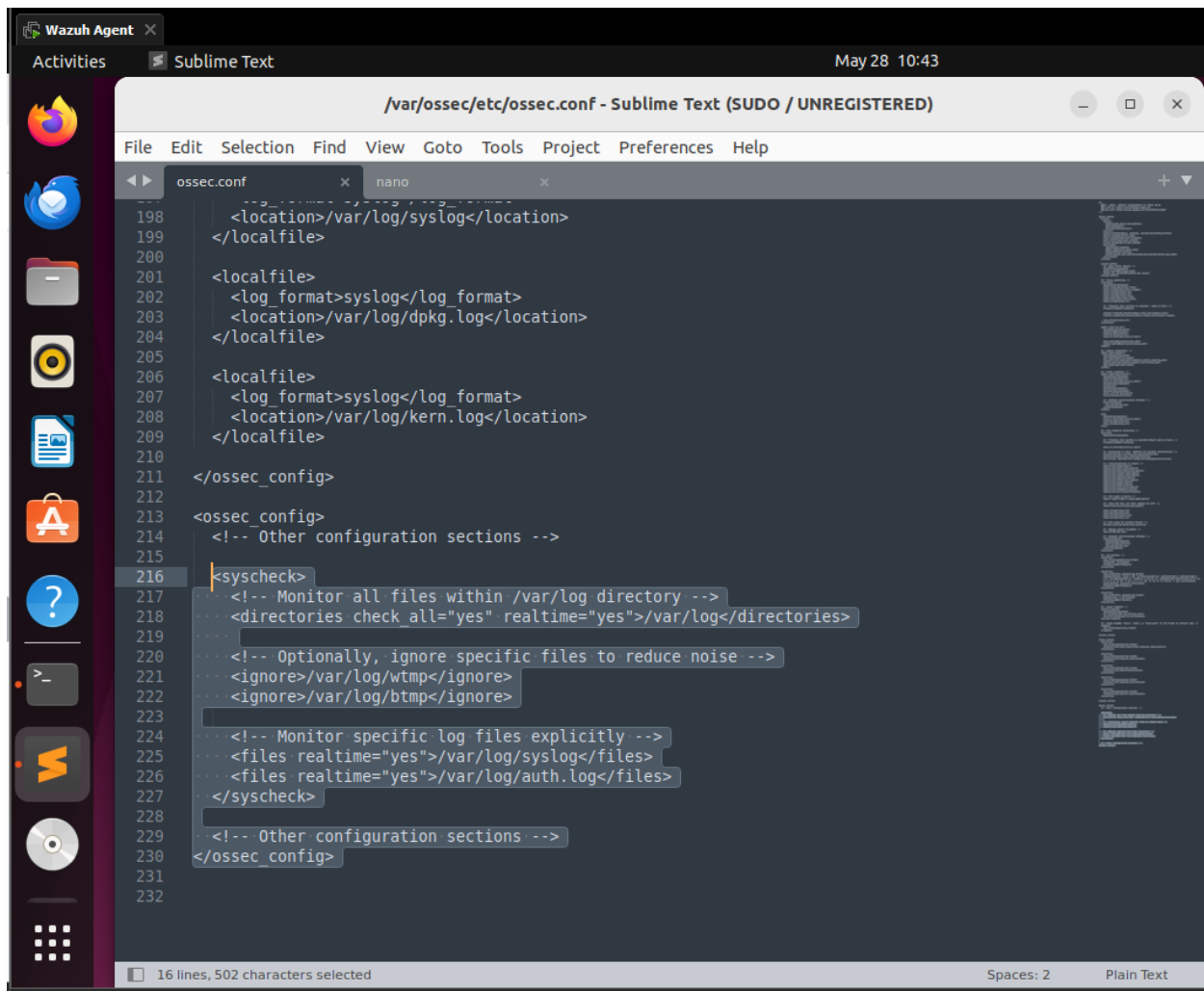


Figure 6.2.1.5

Figure

3. Save and restart Wazuh-Agent.

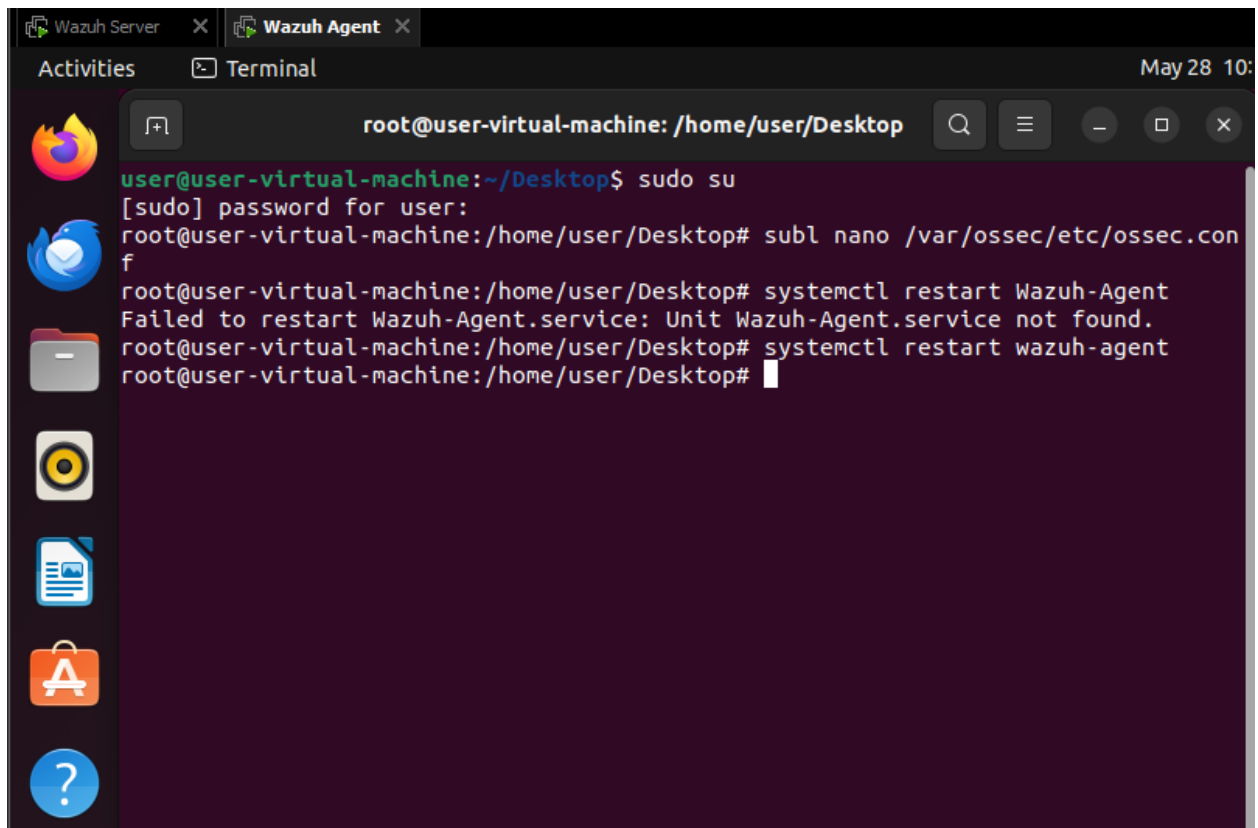


Figure 6.2.1.6

Step 3: Create rules on Wazuh-Manager.

1. Open rules file

Command: `sudo nano /var/ossec/etc/rules/local_rules.xml`

2. Add custom rule to detect deletion.

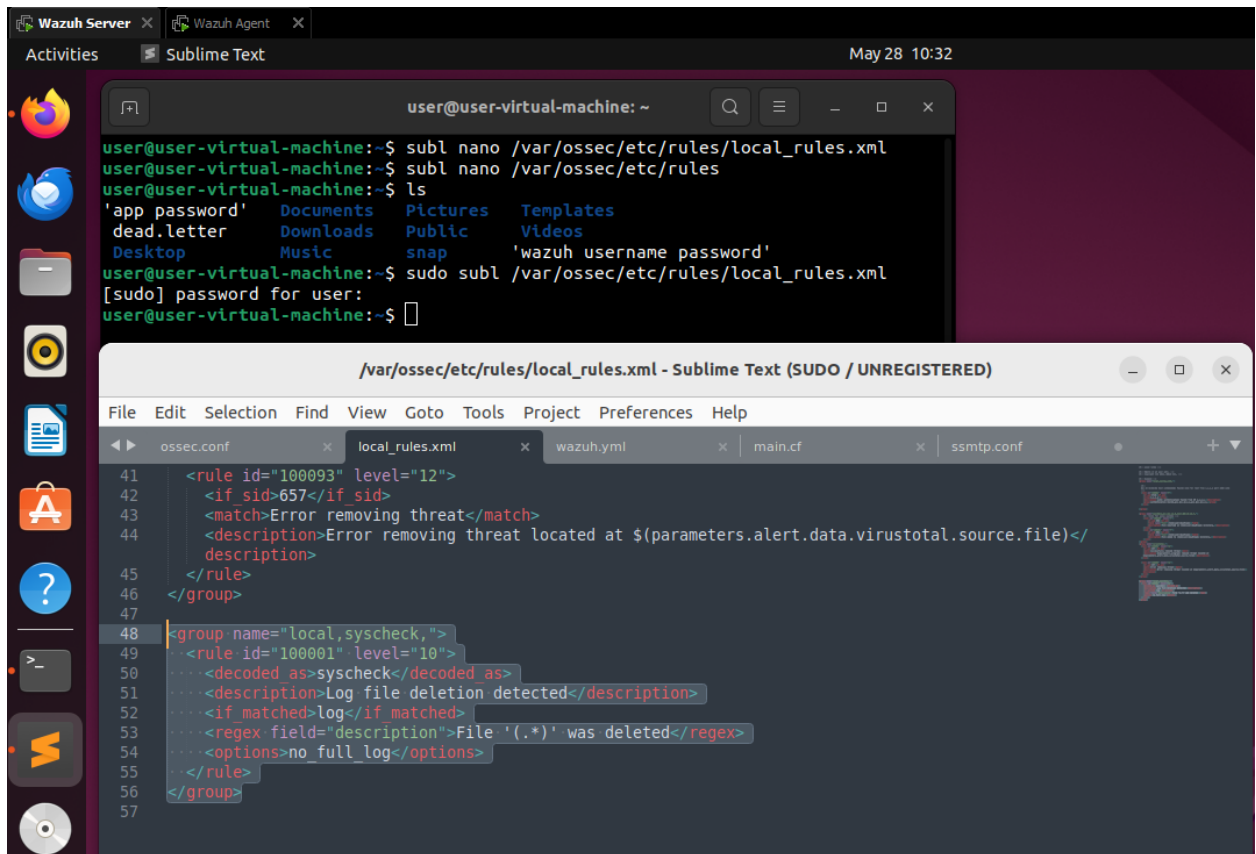


Figure 6.2.1.7

3. Save and restart agent.

Command: `sudo systemctl restart wazuh-manager`

Step 4: Verification and testing

1. Test Log file deletion and Security events on Wazuh-manager

- Command: `sudo rm /var/log/syslog`

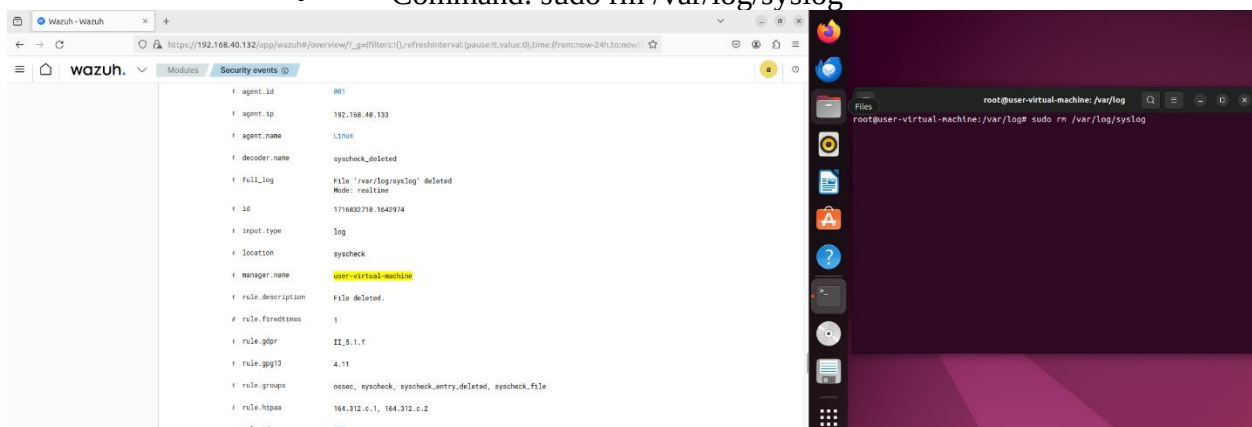


Figure 6.2.1.7

2. Email Alert Notification

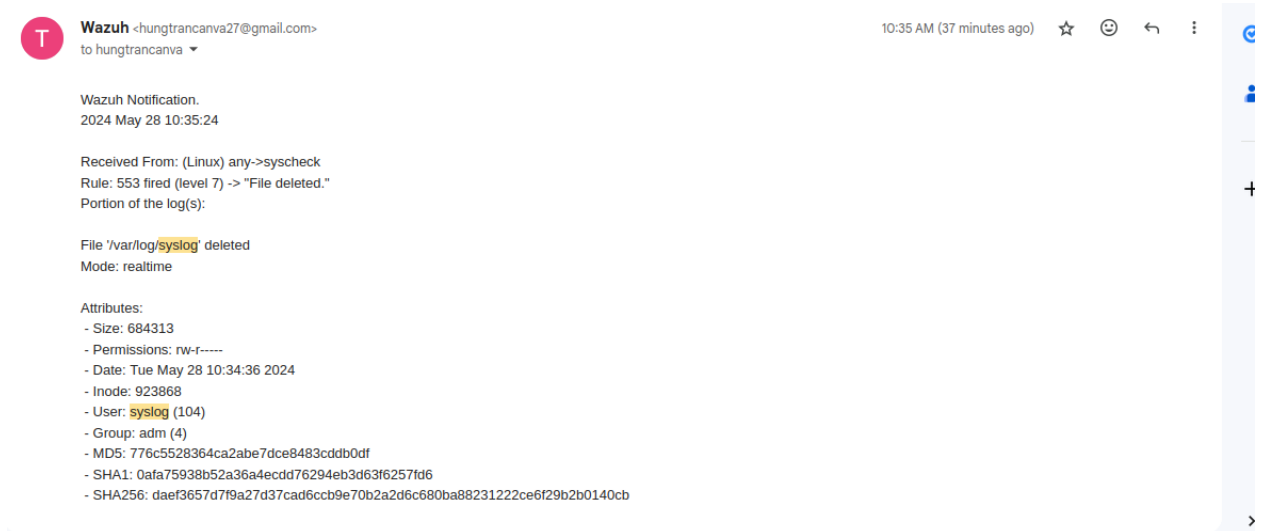


Figure 6.2.1.9

2.2) Solution 2: Additional Measures to Prevent Log File Deletions or Modifications (Wazuh).

1. Change File Permissions

In this step, we will only give root the permissions.

Step 1: Change ownership and permission (root) of the log files.

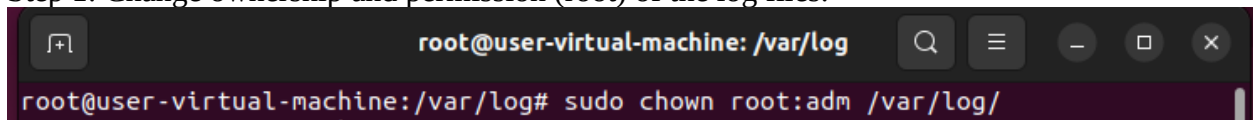


Figure 6.2.2.1

Step 2: Ensure syslog has write permission.

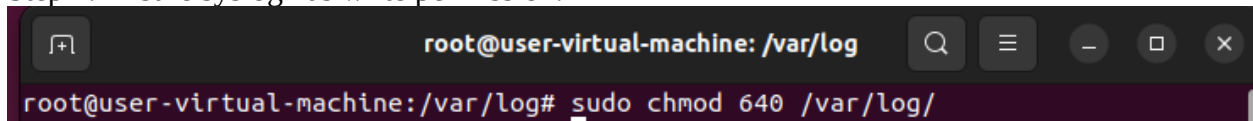


Figure 6.2.2.2

Step 3: Verify with different user.

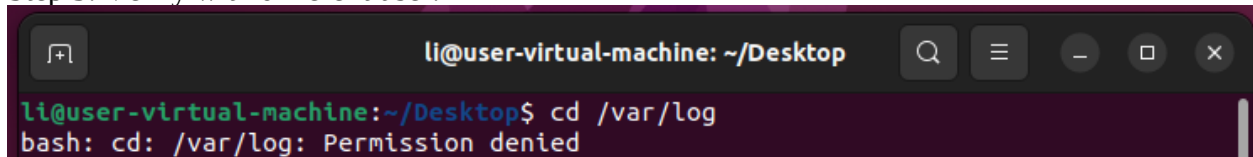
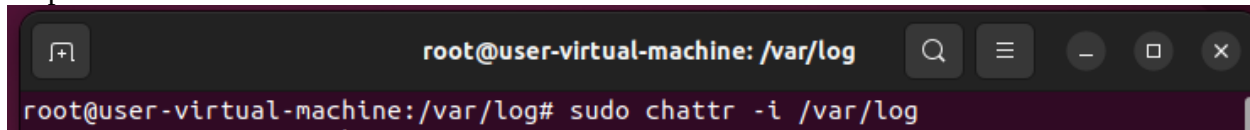


Figure 6.2.2.3

2. Use Immutable Attribute

This step is to set immutable attributes to prevent any changes to log file.

Step 1: Set immutable attributes.



```
root@user-virtual-machine: /var/log
root@user-virtual-machine:/var/log# sudo chattr -i /var/log
```

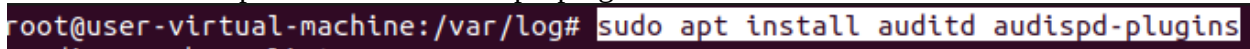
Figure 6.2.2.4

3. Use Auditd to monitor directories

Auditd is an auditing framework used on Ubuntu to help monitor log activities of the system. Auditd can track user activities such as command execution or login attempts but also it can detect any system changes.

Step 1: Install 'auditd'

Command: sudo apt install auditd audispd-plugins

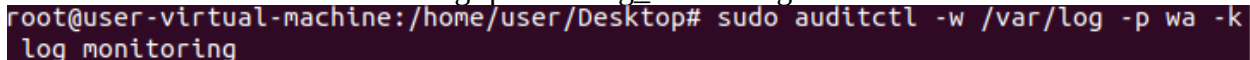


```
root@user-virtual-machine:/var/log# sudo apt install auditd audispd-plugins
```

Figure 6.2.2.5

Step 2: Add rule to monitor configuration in log file.

Command: sudo auditctl -w /var/log -p wa -k log_monitoring

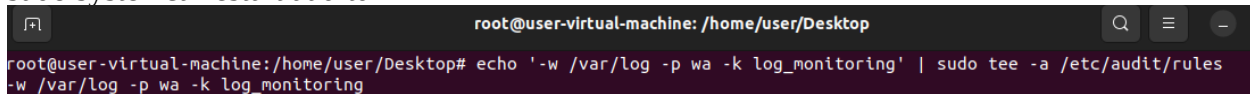


```
root@user-virtual-machine:/home/user/Desktop# sudo auditctl -w /var/log -p wa -k log_monitoring
```

Figure 6.2.2.6

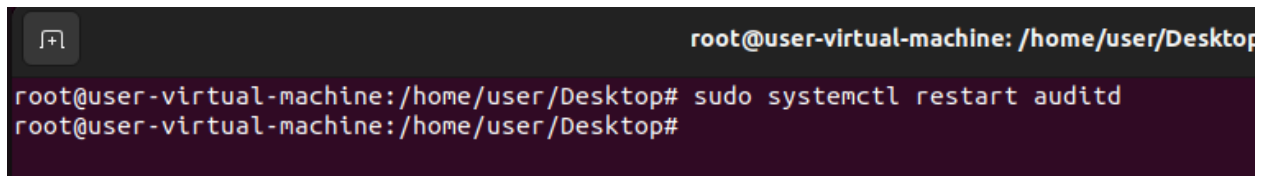
Step 3: Make this rule persistent and restart 'auditd'

Command: echo '-w /var/log -p wa -k log_monitoring' | sudo tee -a /etc/audit/rules
sudo systemctl restart auditd



```
root@user-virtual-machine:/home/user/Desktop# echo '-w /var/log -p wa -k log_monitoring' | sudo tee -a /etc/audit/rules
-w /var/log -p wa -k log_monitoring
```

Figure 6.2.2.7



```
root@user-virtual-machine:/home/user/Desktop# sudo systemctl restart auditd
root@user-virtual-machine:/home/user/Desktop#
```

Figure 6.2.2.8

VI) Network Security Challenges

While tools mentioned in previous sections are robust at protecting the network, they also have drawbacks. The following section will discuss the challenges related to securing network, focusing on the following tools:

- IPTables

- Snort
- Elastic
- Wazuh

Firstly, the tools need to be configured manually, which requires the equivalent expertise and time to set up. Security knowledge is vital to use these tools effectively, acknowledging characteristic of the traffic and the network itself as well as the configuration. Furthermore, significant customization is necessary when implementing of these tools to existing network and infrastructure, making it complex and time consuming. Due to complexity of implementation and management, they can be easily misconfigured, causing performance issues and vulnerabilities in the network.

Secondly, monitoring and filtering is a continuous process, these tools demand on computer power, storages and network capabilities, these issues are easily addressed with additional hardware and process power but come at high cost. In general, IDS and IPS are known to affect network performance such as latency, Alka and Lalit (2020) shows that Snort performance is degrade in large traffic and its struggle to deal with larger packets, as shown in the increased packet drop rate. In addition, having a large set of IP rules also slower packet inspection, such as Iptables is affected by this. In conclusion, these tools are resource extensive and may affect network performance.

Thirdly, systems such as SIEM, firewall, IPS and IDS sometimes produces inaccurate results, false positives and false negatives are unavoidable and requires cautions from those monitoring on these systems.

Lastly, most tools presented are open source, meaning users have limited feature access. For example, Snort and selfhosted Wazuh requires manual security rules update while paid products such as Wazuh-cloud, paid Snort, and Elastic are updated automatically. Another example comparing Iptables to modern firewalls, Iptables fall short of features such as deep packet inspection, VPN capabilities and user friendliness. While provided tools are effective solutions, they have limited features or less effectiveness compared to dedicated/paid tools.

VII) Conclusion

As the defensive side, we must understand the attacker techniques to prevent him in each phase. During reconnaissance, we should implement mail security protocols like SPF, DKIM and DMARC for email spoofing prevention. Next, implement zone-based firewall that can segment the network and configure the Iptables properly along with Snort can prevent scanning. After that, we should isolate affected network devices and analyze malware behaviors, then write Yara rules for SIEM tool like elastic to prevent it entering the system in the future. Configure Wazuh to detect any anomalies action and prevent log deletion by using Wazuh or Auditd.

Word count: 3,221

VIII) References

1. Wazuh (n.d.). *Configuring email alerts - Wazuh server · Wazuh documentation*. [online] documentation.wazuh.com. Available at: <https://documentation.wazuh.com/current/user-manual/manager/manual-email-report/index.html> [Accessed 18 Jun. 2024].
2. Wazuh. “Basic Settings - File Integrity Monitoring · Wazuh Documentation.” *Documentation.wazuh.com*, documentation.wazuh.com/current/user-manual/capabilities/file-integrity/basic-settings.html. Accessed 18 June 2024.
3. Pandey, Sudhir Kumar, and B.M. Mehtre. “Performance of Malware Detection Tools: A Comparison.” *2014 IEEE International Conference on Advanced Communications, Control and Computing Technologies*, May 2014, <https://doi.org/10.1109/icaccct.2014.7019422>.
4. A, Monnappa K. *Learning Malware Analysis: Explore the Concepts, Tools, and Techniques to Analyze and Investigate Windows Malware*. Google Books, Packt Publishing Ltd, 29 June 2018, books.google.com.vn/books?hl=en&lr=&id=QsNiDwAAQBAJ&oi=fnd&pg=PP1&dq=HxD+malware+analysis&ots=FJRCLmki5N&sig=4xf6XdhU0yP8ST4zPe8NMg8AiHc&redir_esc=y#v=onepage&q=HxD%20malware%20analysis&f=false. Accessed 19 June 2024.
5. Wazuh. “Components - Getting Started with Wazuh · Wazuh Documentation.” *Documentation.wazuh.com*, documentation.wazuh.com/current/getting-started/components/index.html.
6. Wazuh. “Detecting and Removing Malware Using VirusTotal Integration.” *Documentation.wazuh.com*, documentation.wazuh.com/current/proof-of-concept-guide/detect-remove-malware-virustotal.html.
7. Snort.org. (2020). *Snort - Network Intrusion Detection & Prevention System*. [online] Available at: <https://snort.org/>.
8. Shaimaa H. Abd, Ivan A. Hashim and Ali Sadeq A. Jalal, “Automated Deception Detection Systems, a Review” (2021) *Iraqi Journal of Science*, pp. 70–80. doi:10.24996/ijis.2021.SI.2.8.
9. Alka Gupta and Lalit Sen Sharma, “Performance Analysis and Comparison of Snort on Various Platforms” (2020) *International Journal of Computer Information Systems and Industrial Management Applications*. ISSN 2150-7988 Volume 10 (2020) pp. 023-032
10. Hu, H., Peng, P. and Wang, G. (2018). *Towards Understanding the Adoption of Anti-Spoofing Protocols in Email Systems*. [online] IEEE Xplore. doi:<https://doi.org/10.1109/SecDev.2018.00020>.

Appendix

gophish

Dashboard

Campaigns

Users & Groups

Email Templates

Landing Pages

Sending Profiles

Account Settings

User Management

Webhooks

User Guide

API Documentation

Admins

Admins

gophish

admin

Dashboard

Campaigns

Users & Groups

Email Templates

Landing Pages

Sending Profiles

Account Settings

User Management

Webhooks

User Guide

API Documentation

Campaigns

+ New Campaign

Active Campaigns

Archived Campaigns

No campaigns created yet. Let's create one.

New Campaign

Name:

SCAM MR. S

Email Template:

SCAM mail

Landing Page:

EMPTY

URL:

http://192.168.1.1

Launch Date

May 31st 2024, 6:54 am

Send Emails By (Optional)

Sending Profile:

NOTASCAMMER

Send Test Email

Groups:

> Company

Close

Launch Campaign